



macOS Security Compliance

macOS 26.0

Security Configuration - MACOS_PERSONAL

Tahoe Guidance, Revision 2.0 (2025-12-18)

Table of Contents

1. Foreword	1
2. Scope	2
3. Authors	3
4. Acronyms and Definitions	4
5. Applicable Documents	6
5.1. Government Documents	6
5.2. Non-Government Documents	6
6. iCloud	8
6.1. Disable iCloud Address Book	8
6.2. Disable iCloud Bookmarks	9
6.3. Disable the iCloud Calendar Services	9
6.4. Disable iCloud Document Sync	10
6.5. Disable the iCloud Freeform Services	11
6.6. Disable iCloud Keychain Sync	12
6.7. Disable iCloud Mail	13
6.8. Disable iCloud Photo Library	13
6.9. Disable iCloud Desktop and Document Folder Sync	14
7. macOS	16
7.1. Configure Apple System Log Files Owned by Root and Group to Wheel	16
7.2. Configure Apple System Log Files To Mode 640 or Less Permissive	16
7.3. Enable Authenticated Root	17
7.4. Enforce Installation of XProtect Remediator and Gatekeeper Updates Automatically	18
7.5. Enable Gatekeeper	19
7.6. Disable Genmoji AI Creation	20
7.7. Remove Guest Folder if Present	20
7.8. Disable Handoff	21
7.9. Secure User's Home Folders	22
7.10. Disable the Built-in Web Server	22
7.11. Disable Apple Intelligence Image Playground	23
7.12. Configure Install.log Retention to 365	24
7.13. Enable Library Validation	25
7.14. Disable Apple Intelligence Mail Smart Replies	25
7.15. Disable Apple Intelligence Mail Summary	26
7.16. Enable Apple Mobile File Integrity	27
7.17. Configure System Log Files Owned by Root and Group to Wheel	27
7.18. Configure System Log Files to Mode 640 or Less Permissive	28
7.19. Disable Apple Intelligence Notes Transcription	29
7.20. Disable Apple Intelligence Notes Transcription Summary	29

7.21. Enforce On Device Dictation	30
7.22. Remove Password Hint From User Accounts	31
7.23. Disable Photos Enhanced Visual Search	32
7.24. Disable Root Login	32
7.25. Ensure Advertising Privacy Protection in Safari Is Enabled	33
7.26. Disable Automatic Opening of Safe Files in Safari	34
7.27. Ensure Prevent Cross-site Tracking in Safari Is Enabled	34
7.28. Disable Apple Intelligence Safari Reader Summary	35
7.29. Ensure Show Safari shows the Status Bar is Enabled	36
7.30. Ensure Warn When Visiting A Fraudulent Website in Safari Is Enabled	36
7.31. Ensure Secure Boot Level Set to Full	37
7.32. Ensure System Integrity Protection is Enabled	38
7.33. Ensure Sleep and Display Sleep Is Enabled on Apple Silicon Devices	39
7.34. Enforce Software Update App Update Updates Automatically	40
7.35. Configure Sudo To Log Events	40
7.36. Configure Sudo Timeout Period to 0	41
7.37. Configure Sudoers Timestamp Type	41
7.38. Ensure System Volume is Read Only	42
7.39. Ensure Appropriate Permissions Are Enabled for System Wide Applications	43
7.40. Ensure Secure Keyboard Entry Terminal.app is Enabled	44
7.41. Disable Trivial File Transfer Protocol Service	44
7.42. Enable Time Synchronization Daemon	45
7.43. Disable Login to Other User's Active and Locked Sessions	46
7.44. Disable Unix-to-Unix Copy Protocol Service	47
7.45. Ensure No World Writable Files Exist in the Library Folder	48
7.46. Ensure No World Writable Files Exist in the System Folder	49
7.47. Disable Apple Intelligence Writing Tools	49
8. Password Policy	51
8.1. Limit Consecutive Failed Login Attempts to 5	51
8.2. Set Account Lockout Time to 15 Minutes	52
8.3. Require Passwords Contain a Minimum of One Numeric Character	53
8.4. Require a Minimum Password Length of 15 Characters	54
8.5. Prohibit Repeating, Ascending, and Descending Character Sequences	55
8.6. Require Passwords Contain a Minimum of One Special Character	56
9. System Settings	58
9.1. Prevent Apple Watch from Terminating a Session Lock	58
9.2. Disable Unattended or Automatic Logon to the System	59
9.3. Disable Content Caching Service	59
9.4. Enforce Critical Security Updates to be Installed	60
9.5. Disable Sending Diagnostic and Usage Data to Apple	61
9.6. Disable External Intelligence Integrations	62

9.7. Disable External Intelligence Integration Sign In	63
9.8. Enforce FileVault	63
9.9. Enable macOS Application Firewall	64
9.10. Enable Firewall Stealth Mode	65
9.11. Apply Gatekeeper Settings to Block Applications from Unidentified Developers	66
9.12. Configure Gatekeeper to Disallow End User Override	67
9.13. Disable Guest Access to Shared SMB Folders	68
9.14. Disable the Guest Account	69
9.15. Secure Hot Corners	69
9.16. Disable Sending Audio Recordings and Transcripts to Apple	71
9.17. Disable Improve Search Information to Apple	71
9.18. Disable Improve Siri and Dictation Information to Apple	72
9.19. Disable Internet Sharing	73
9.20. Enable Location Services	74
9.21. Configure Login Window to Show A Custom Message	75
9.22. Disable Media Sharing	75
9.23. Disable Password Hints	76
9.24. Disable Personalized Advertising	77
9.25. Disable Printer Sharing	78
9.26. Disable Remote Apple Events	78
9.27. Disable Remote Management	79
9.28. Enforce Session Lock After Screen Saver is Started	80
9.29. Enforce Screen Saver Password	81
9.30. Enforce Screen Saver Timeout	81
9.31. Disable Siri	82
9.32. Ensure Siri Listen For is Disabled	83
9.33. Disable Server Message Block Sharing	84
9.34. Enforce Software Update Downloads Updates Automatically	84
9.35. Ensure Software Update is Updated and Current	85
9.36. Disable SSH Server for Remote Access Sessions	86
9.37. Require Administrator Password to Modify System-Wide Preferences	86
9.38. Configure Time Machine for Automatic Backups	89
9.39. Ensure Time Machine Volumes are Encrypted	89
9.40. Configure macOS to Use an Authorized Time Server	90
9.41. Enforce macOS Time Synchronization	91
9.42. Ensure Wake for Network Access Is Disabled	92
10. Inherent	93
10.1. Audit Record Reduction and Report Generation	93
10.2. Allow Information Transfer with Other Operating Systems	93
10.3. Ensure Separate Execution Domain for Processes	94
10.4. Allow Administrators to Modify Security Settings and System Attributes	94

10.5. Protect Audit Integrity with Cryptographic Mechanisms	94
10.6. Enforce Access Restrictions	95
10.7. Generate Error Messages without Exploitable Information	95
10.8. Configure System to Fail to a Known Safe State if System Initialization, Shutdown, or Abort Fails	96
10.9. Allow Administrators to Promote Other Users to Administrator Status	96
10.10. Configure the System to Implement Approved Cryptography to Protect Information	96
10.11. Configure the System to Protect Memory from Unauthorized Code Execution	97
10.12. Configure the System to Separate User and System Functionality	98
10.13. Only allow authorized users to select auditable events	98
10.14. Limit Concurrent GUI Sessions to 10 for all Accounts	98
10.15. Enforce Approved Authorization for Logical Access	99
10.16. Display logoff capability and message to prevent exploitation	99
10.17. Ensure the System Implements Malicious Code Protection Mechanisms	100
10.18. Map identity for PKI based authentication	101
10.19. Enforce multifactor authentication for network access to privileged accounts	101
10.20. Enforce multifactor authentication for network access to non-privileged accounts	101
10.21. Obscure Passwords	102
10.22. The macOS system must uniquely identify peripherals before establishing a connection.	102
10.23. Must behave in predictable and documented manner	102
10.24. Prevent Software From Executing at Higher Privilege Levels than Users Executing The Software	103
10.25. Configure the System to Block Non-Privileged Users from Executing Privileged Functions	103
10.26. Configure the System to Prevent the Unauthorized Disclosure of Data via Shared Resources	104
10.27. Prohibit Remote Activation of Collaborative Computing Devices	104
10.28. Provide Ability to Disconnect or Disable Remote Access	105
10.29. Require users to reauthenticate for privilege escalation	105
10.30. Require users to reauthenticate when changing authenticators	105
10.31. Control remote access methods	106
10.32. Must remove all software components after updated versions installed	106
10.33. Ensure all Federal Laws, Executive Orders, Directives, Policies, Regulations, Standards, and Guidance for Authentication to a Cryptographic Module are Met	106
10.34. Protected Storage for Cryptographic Keys	107
10.35. Configure the System to Separate User and System Functionality	107
10.36. Encrypt Stored Passwords	108
10.37. The macOS Version Must Be Supported by the Vendor	108
10.38. Terminate all sessions and network connections when maintenance is completed.	108
10.39. Uniquely Identify Users and Processes	109

10.40. Verify remote disconnection of sessions	109
10.41. Automatically Remove or Disable Emergency Accounts within 72 Hours.	109
10.42. Force Password Change at Next Logon.	110
10.43. Automatically Remove or Disable Temporary User Accounts within 72 Hours.	110
11. Permanent Findings	112
11.1. Prevent the Use of Dictionary Words for Passwords.	112
12. Supplemental	113
12.1. CIS Manual Recommendations.	113

Chapter 1. Foreword

The macOS Security Compliance Project is an open source effort to provide a programmatic approach to generating security guidance. The configuration settings in this document were derived from National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, *Security and Privacy Controls for Information Systems and Organizations*, Revision 5.

This project can be used as a resource to easily create customized security baselines of technical security controls by leveraging a library of atomic actions which are mapped to the compliance requirements defined in NIST SP 800-53 (Rev. 5). It can also be used to develop customized guidance to meet the particular cybersecurity needs of any organization.

The objective of this effort was to simplify and radically accelerate the process of producing up-to-date macOS security guidance that is also accessible to any organization and tailorable to meet each organization's specific security needs.

Any and all risk based decisions to tailor the content produced by this project in order to meet the needs of a specific organization shall be approved by the responsible Information System Owner (ISO) and Authorizing Official (AO) and formally documented in their System Security Plan (SSP). While the project attempts to provide settings to meet compliance requirements, it is recommended that each rule be reviewed by your organization's Information System Security Officer (ISSO) prior to implementation.

Chapter 2. Scope

This guide describes the actions to take when securing a macOS 26.0 system against the MACOS_PERSONAL (Tailored from ALL_RULES) security baseline.

Information System Security Officers and benchmark creators can use this catalog of settings in order to assist them in security benchmark creation. This list is a catalog, not a checklist or benchmark, and satisfaction of every item is not likely to be possible or sensible in many operational scenarios.

Chapter 3. Authors

Security configuration tailored by:

Adam M. Furman	None
----------------	------

macOS Security Compliance Project

Bob Gendler	National Institute of Standards and Technology
Dan Brodjieski	National Aeronautics and Space Administration
Allen Golbig	Jamf

Chapter 4. Acronyms and Definitions

Table 1. Acronyms and Abbreviations

AES	Advanced Encryption Standard
ABM	Apple Business Manager
AFP	Apple Filing Protocol
ALF	Application Layer Firewall
AO	Authorizing Official
API	Application Programming Interface
ARD	Apple Remote Desktop
CA	Certificate Authority
CIS	Center for Internet Security
CMMC	Cybersecurity Maturity Model Certification
CNSSI	Committee on National Security Systems
CRL	Certificate Revocation List
DISA	Defense Information Systems Agency
DMA	Direct Memory Access
FISMA	Federal Information Security Modernization Act
FPKI	Federal Public Key Infrastructure
IR	Infrared
ISO	Information System Owner
ISSO	Information System Security Officer
MDM	Mobile Device Management
NASA	National Aeronautics and Space Administration
NFS	Network File System
NIST	National Institute of Standards and Technology
NSA	National Security Agency
OCSF	Online Certificate Status Protocol
ODV	Organization Defined Values
OS	Operating System
PF	Packet Filter
PIV	Personal Identity Verification
PIV-M	Personal Identity Verification Mandatory
PKI	Public Key Infrastructure
RBD	Risk Based Decision

SIP	System Integrity Protection
SMB	Server Message Block
SSH	Secure Shell
SSP	System Security Plan
STIG	Security Technical Implementation Guide
UAMDM	User Approved MDM
UUCP	Unix-to-Unix Copy Protocol

Table 2. Definitions

Baseline	A baseline is a predefined set of controls (also referred to as "a catalog" of settings) that address the protection needs of an organization's information systems. A baseline serves as a starting point for the creation of security benchmarks.
Benchmark	Benchmarks are a defined list of settings with values that an organization has defined.

Chapter 5. Applicable Documents

5.1. Government Documents

Table 3. National Institute of Standards and Technology (NIST)

Document Number or Descriptor	Document Title
NIST Special Publication 800-53 Rev 5	<i>NIST Special Publication 800-53 Rev 5.1.1</i>
NIST Special Publication 800-63	<i>NIST Special Publication 800-63</i>
NIST Special Publication 800-171	<i>NIST Special Publication 800-171 Rev 3</i>
NIST Special Publication 800-219	<i>NIST Special Publication 800-219 Rev 1</i>

Table 4. Defense Information Systems Agency (DISA)

Document Number or Descriptor	Document Title
STIG Ver 1, Rel 1	<i>Apple macOS 26 (Tahoe) STIG</i>

Table 5. Cybersecurity Maturity Model Certification (CMMC)

Document Number or Descriptor	Document Title
CMMC Model Overview v2.0	<i>Cybersecurity Maturity Model Certification (CMMC) Model Overview v2.0</i>

Table 6. Committee on National Security Systems (CNSS)

Document Number or Descriptor	Document Title
CNSSI No. 1253	<i>Security Categorization and Control Selection for National Security Systems</i>

Table 7. Baseline Informatiebeveiliging Overheid (BIO)

Document Number or Descriptor	Document Title
BIO	<i>Baseline Informatiebeveiliging Overheid (BIO)</i>
BIO2 GitHub Repository	<i>BIO2 GitHub Repository</i>

5.2. Non-Government Documents

Table 8. Apple

Document Number or Descriptor	Document Title
Apple Platform Security Guide	<i>Apple Platform Security</i>
Apple Platform Deployment	<i>Apple Platform Deployment</i>
Apple Platform Certifications	<i>Apple Platform Certifications</i>
Profile-Specific Payload Keys	<i>Profile-Specific Payload Keys</i>

Table 9. Center for Internet Security

Document Number or Descriptor	Document Title
Apple macOS 26.0	<i>CIS Apple macOS 26.0 Benchmark version 1.0.0</i>

Chapter 6. iCloud

This section contains the configuration and enforcement of iCloud and the Apple ID service settings.



The check/fix commands outlined in this section *MUST* be run by a user with with elevated privileges.

6.1. Disable iCloud Address Book

The macOS built-in Contacts.app connection to Apple’s iCloud service *MUST* be disabled.

Apple’s iCloud service does not provide an organization with enough control over the storage and access of data, and, therefore, automated contact synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudAddressBook').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudAddressBook</key>
<false/>
```

ID	icloud_addressbook_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95140-0

6.2. Disable iCloud Bookmarks

The macOS built-in Safari.app bookmark synchronization via the iCloud service *MUST* be disabled.

Apple’s iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated bookmark synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudBookmarks').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudBookmarks</key>
<false/>
```

ID	icloud_bookmarks_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95142-6

6.3. Disable the iCloud Calendar Services

The macOS built-in Calendar.app connection to Apple’s iCloud service *MUST* be disabled.

Apple’s iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated calendar synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudCalendar').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudCalendar</key>
<false/>
```

ID	icloud_calendar_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95143-4

6.4. Disable iCloud Document Sync

The macOS built-in iCloud document synchronization service *MUST* be disabled to prevent organizational data from being synchronized to personal or non-approved storage.

Apple's iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated document synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudDocumentSync').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudDocumentSync</key>
<false/>
```

ID	icloud_drive_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95144-2

6.5. Disable the iCloud Freeform Services

The macOS built-in Freeform.app connection to Apple's iCloud service *MUST* be disabled.

Apple's iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated calendar synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudFreeform').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudFreeform</key>
<false/>
```

ID	icloud_freeform_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95145-9

6.6. Disable iCloud Keychain Sync

The macOS system’s ability to automatically synchronize a user’s passwords to their iCloud account *MUST* be disabled.

Apple’s iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, password management and synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudKeychainSync').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudKeychainSync</key>
<false/>
```

ID	icloud_keychain_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95147-5

6.7. Disable iCloud Mail

The macOS built-in Mail.app connection to Apple’s iCloud service *MUST* be disabled.

Apple’s iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated mail synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudMail').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudMail</key>
<false/>
```

ID	icloud_mail_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95148-3

6.8. Disable iCloud Photo Library

The macOS built-in Photos.app connection to Apple’s iCloud service *MUST* be disabled.

Apple’s iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated photo synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudPhotoLibrary').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudPhotoLibrary</key>
<false/>
```

ID	icloud_photos_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95150-9

6.9. Disable iCloud Desktop and Document Folder Sync

The macOS system's ability to automatically synchronize a user's desktop and documents folder to their iCloud Drive *MUST* be disabled.

Apple's iCloud service does not provide an organization with enough control over the storage and access of data and, therefore, automated file synchronization *MUST* be controlled by an organization approved service.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowCloudDesktopAndDocuments').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowCloudDesktopAndDocuments</key>
<false/>
```

ID	icloud_sync_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95153-3

Chapter 7. macOS

This section contains the configuration and enforcement of operating system settings.



The check/fix commands outlined in this section *MUST* be run by a user with elevated privileges.

7.1. Configure Apple System Log Files Owned by Root and Group to Wheel

The Apple System Logs (ASL) *MUST* be owned by root.

ASL logs contain sensitive data about the system and users. If ASL log files are set to only be readable and writable by system administrators, the risk is mitigated.

To check the state of the system, run the following command(s):

```
/usr/bin/stat -f '%Su:%Sg:%N' $(/usr/bin/grep -e '^>' /etc/asl.conf /etc/asl/* |
/usr/bin/awk '{ print $2 }') 2> /dev/null | /usr/bin/awk '!/^root:wheel:/{print $1}' |
/usr/bin/wc -l | /usr/bin/tr -d ' '
```

If the result is not 0, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/chown root:wheel $(/usr/bin/stat -f '%Su:%Sg:%N' $(/usr/bin/grep -e '^>'
/etc/asl.conf /etc/asl/* | /usr/bin/awk '{ print $2 }') 2> /dev/null |
/usr/bin/awk '!/^root:wheel:/{print $1}' | /usr/bin/awk -F":"
'!/^root:wheel:/{print $3}')
```

ID	os_asl_log_files_owner_group_configure	
References	800-53r5	• SI-11
	CCE	• CCE-95161-6

7.2. Configure Apple System Log Files To Mode 640 or Less Permissive

The Apple System Logs (ASL) *MUST* be configured to be writable by root and readable only by the root user and group wheel. To achieve this, ASL log files *MUST* be configured to mode 640 permissive or less; thereby preventing normal users from reading, modifying or deleting audit logs.

System logs frequently contain sensitive information that could be used by an attacker. Setting the correct permissions mitigates this risk.

To check the state of the system, run the following command(s):

```
/usr/bin/stat -f '%A:%N' $(/usr/bin/grep -e '^>' /etc/asl.conf /etc/asl/* |  
/usr/bin/awk '{ print $2 }') 2> /dev/null | /usr/bin/awk '!/640/{print $1}' |  
/usr/bin/wc -l | /usr/bin/tr -d ' '
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/chmod 640 $(/usr/bin/stat -f '%A:%N' $(/usr/bin/grep -e '^>' /etc/asl.conf  
/etc/asl/* | /usr/bin/awk '{ print $2 }') 2> /dev/null | /usr/bin/awk -F":"  
'!/640/{print $2}')
```

ID	os_asl_log_files_permissions_configure	
References	800-53r5	• SI-11
	CCE	• CCE-95162-4

7.3. Enable Authenticated Root

Authenticated Root *MUST* be enabled.

When Authenticated Root is enabled the macOS is booted from a signed volume that is cryptographically protected to prevent tampering with the system volume.



Authenticated Root is enabled by default on macOS systems.



If more than one partition with macOS is detected, the csrutil command will hang awaiting input.

To check the state of the system, run the following command(s):

```
/usr/libexec/mdmclient QuerySecurityInfo 2>/dev/null | /usr/bin/grep -c  
"AuthenticatedRootVolumeEnabled = 1;"
```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/csrutil authenticated-root enable
```



To re-enable "Authenticated Root", boot the affected system into "Recovery" mode, launch "Terminal" from the "Utilities" menu, and run the command.

ID	os_authenticated_root_enable	
References	800-53r5	• AC-3 • CM-5 • MA-4(1) • SC-34 • SI-7, SI-7(6)
	CCE	• CCE-95164-0

7.4. Enforce Installation of XProtect Remediator and Gatekeeper Updates Automatically

Software Update *MUST* be configured to update XProtect Remediator and Gatekeeper automatically.

This setting enforces definition updates for XProtect Remediator and Gatekeeper; with this setting in place, new malware and adware that Apple has added to the list of malware or untrusted software will not execute. These updates do not require the computer to be restarted.

<https://support.apple.com/en-us/HT207005>



Software update will automatically update XProtect Remediator and Gatekeeper by default in the macOS.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SoftwareUpdate')\
.objectForKey('ConfigDataInstall').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SoftwareUpdate) payload type:

```
<key>ConfigDataInstall</key>
<true/>
```

ID	os_config_data_install_enforce	
References	800-53r5	• SI-2(5) • SI-3
	CCE	• CCE-95176-4

7.5. Enable Gatekeeper

Gatekeeper *MUST* be enabled.

Gatekeeper is a security feature that ensures that applications are digitally signed by an Apple-issued certificate before they are permitted to run. Digital signatures allow the macOS host to verify that the application has not been modified by a malicious third party.

Administrator users will still have the option to override these settings on a case-by-case basis.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.systempolicy.control')\
.objectForKey('EnableAssessment').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.systempolicy.control) payload type:

```
<key>EnableAssessment</key>
<true/>
```

ID	os_gatekeeper_enable	
References	800-53r5	• CM-14 • CM-5 • SI-3 • SI-7(1), SI-7(15)
	CCE	• CCE-95195-4

7.6. Disable Genmoji AI Creation

Apple Intelligence features such as Genmoji *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowGenmoji').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowGenmoji</key>
<false/>
```

ID	os_genmoji_disable	
References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95196-2

7.7. Remove Guest Folder if Present

The guest folder *MUST* be deleted if present.

To check the state of the system, run the following command(s):

```
/bin/ls /Users/ | /usr/bin/grep -c "Guest"
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/rm -Rf /Users/Guest
```

ID	os_guest_folder_removed	
References	800-53r5	• N/A
	CCE	• CCE-95198-8

7.8. Disable Handoff

Handoff *MUST* be disabled.

Handoff allows you to continue working on a document or project when the user switches from one Apple device to another. Disabling Handoff prevents data transfers to unauthorized devices.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowActivityContinuation').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowActivityContinuation</key>
<false/>
```

ID	os_handoff_disable
----	--------------------

References	800-53r5	• AC-20 • AC-3 • CM-7, CM-7(1)
	CCE	• CCE-95199-6

7.9. Secure User's Home Folders

The system *MUST* be configured to prevent access to other user's home folders.

The default behavior of macOS is to allow all valid users access to the top level of every other user's home folder while restricting access only to the Apple default folders within.

To check the state of the system, run the following command(s):

```
/usr/bin/find /System/Volumes/Data/Users -mindepth 1 -maxdepth 1 -type d ! \( -perm 700 -o -perm 711 \) | /usr/bin/grep -v "Shared" | /usr/bin/grep -v "Guest" | /usr/bin/wc -l | /usr/bin/xargs
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
IFS=$'\n'
for userDirs in $( /usr/bin/find /System/Volumes/Data/Users -mindepth 1 -maxdepth 1 -type d ! \( -perm 700 -o -perm 711 \) | /usr/bin/grep -v "Shared" | /usr/bin/grep -v "Guest" ); do
    /bin/chmod og-rwx "$userDirs"
done
unset IFS
```

ID	os_home_folders_secure	
References	800-53r5	• AC-6
	CCE	• CCE-95203-6

7.10. Disable the Built-in Web Server

The built-in web server which is managed by launchd is a non-essential service built into macOS and *MUST* be disabled and not running.



The built in web server service is disabled at startup by default macOS.

To check the state of the system, run the following command(s):

```
result="FAIL"
enabled=$(/bin/launchctl print-disabled system | /usr/bin/grep '"org.apache.httpd" =>
enabled')
running=$(/bin/launchctl print system/org.apache.httpd 2>/dev/null)

if [[ -z "$running" ]] && [[ -z "$enabled" ]]; then
    result="PASS"
elif [[ -n "$running" ]]; then
    result=result+" RUNNING"
elif [[ -n "$enabled" ]]; then
    result=result+" ENABLED"
fi
echo $result
```

If the result is not **PASS**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/apachectl stop 2>/dev/null
/bin/launchctl disable system/org.apache.httpd
```

ID	os_httpd_disable	
References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95204-4

7.11. Disable Apple Intelligence Image Playground

Apple Intelligence features such as Image Playground *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowImagePlayground').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowImagePlayground</key>
<false/>
```

ID	os_image_playground_disable	
References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95207-7

7.12. Configure Install.log Retention to 365

The install.log *MUST* be configured to require records be kept for a organizational defined value before deletion, unless the system uses a central audit record storage facility.

To check the state of the system, run the following command(s):

```
/usr/sbin/aslmanager -dd 2>&1 | /usr/bin/awk '/\/var\/log\/install.log$/ {count++}
/Processing module com.apple.install/,/Finished/ { for (i=1;i<=NR;i++) { if ($i ==
"TTL" 88 $(i+2) >= 365) { ttl="True" }; if ($i == "MAX") {max="True"}}} END{if (count
> 1) { print "Multiple config files for /var/log/install, manually remove the extra
files"} else if (max == "True") { print "all_max setting is configured, must be
removed" } if (ttl != "True") { print "TTL not configured" } else { print "Yes" } }'
```

If the result is not **Yes**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/sed -i '' "s/\* file \\/var\/log\/install.log.\*\/\* file \\/var\/log
\/install.log format='\$(\ (Time\)\(JZ\)\) \$Host \$\ (Sender\)\[\$(PID\)\]:
\$Message' rotate=utc compress file_max=50M size_only ttl=365/g"
/etc/asl/com.apple.install
```



If there are multiple configuration files in /etc/asl that are set to process the file /var/log/install.log, these files will have to be manually removed.

ID	os_install_log_retention_configure	
References	800-53r5	• AU-11 • AU-4
	CCE	• CCE-95211-9

7.13. Enable Library Validation

Library validation *MUST* be enabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.security.libraryvalidation')\
.objectForKey('DisableLibraryValidation').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.security.libraryvalidation) payload type:

```
<key>DisableLibraryValidation</key>
<false/>
```

ID	os_library_validation_enabled	
References	800-53r5	• N/A
	CCE	• CCE-95215-0

7.14. Disable Apple Intelligence Mail Smart Replies

Apple Intelligence features such as Mail Smart Replies that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowMailSmartReplies').js
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowMailSmartReplies</key>
<false/>
```

ID	os_mail_smart_reply_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95222-6

7.15. Disable Apple Intelligence Mail Summary

Apple Intelligence features such as Apple Mail Summary that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowMailSummary').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowMailSummary</key>
<false/>
```


ID	os_mail_summary_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95223-4

7.16. Enable Apple Mobile File Integrity

Mobile file integrity *MUST* be enabled.

To check the state of the system, run the following command(s):

```
/usr/sbin/nvram -p | /usr/bin/grep -c "amfi_get_out_of_my_way=1"
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/nvram boot-args=""
```

ID	os_mobile_file_integrity_enable	
References	800-53r5	• N/A
	CCE	• CCE-95231-7

7.17. Configure System Log Files Owned by Root and Group to Wheel

The system log files *MUST* be owned by root.

System logs contain sensitive data about the system and users. If log files are set to only be readable and writable by system administrators, the risk is mitigated.

To check the state of the system, run the following command(s):

```
/usr/bin/stat -f '%Su:%Sg:%N' $(/usr/bin/grep -v '^#' /etc/newsyslog.conf |
/usr/bin/awk '{ print $1 }') 2> /dev/null | /usr/bin/awk '!/^root:wheel:/{print $1}' |
/usr/bin/wc -l | /usr/bin/tr -d ' '
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/chown root:wheel $(/usr/bin/stat -f '%Su:%Sg:%N' $(/usr/bin/grep -v '^#' /etc/newsyslog.conf | /usr/bin/awk '{ print $1 }')) 2> /dev/null | /usr/bin/awk -F":" '!/^root:wheel:/{print $3}')
```

ID	os_newsyslog_files_owner_group_configure	
References	800-53r5	• SI-11
	CCE	• CCE-95233-3

7.18. Configure System Log Files to Mode 640 or Less Permissive

The system logs *MUST* be configured to be writable by root and readable only by the root user and group wheel. To achieve this, system log files *MUST* be configured to mode 640 permissive or less; thereby preventing normal users from reading, modifying or deleting audit logs. System logs frequently contain sensitive information that could be used by an attacker. Setting the correct permissions mitigates this risk.

To check the state of the system, run the following command(s):

```
/usr/bin/stat -f '%A:%N' $(/usr/bin/grep -v '^#' /etc/newsyslog.conf | /usr/bin/awk '{ print $1 }') 2> /dev/null | /usr/bin/awk '!/640/{print $1}' | /usr/bin/wc -l | /usr/bin/tr -d ' '
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/chmod 640 $(/usr/bin/stat -f '%A:%N' $(/usr/bin/grep -v '^#' /etc/newsyslog.conf | /usr/bin/awk '{ print $1 }')) 2> /dev/null | /usr/bin/awk '!/640/{print $1}' | awk -F":" '!/640/{print $2}')
```

ID	os_newsyslog_files_permissions_configure
----	--

References	800-53r5	• SI-11
	CCE	• CCE-95234-1

7.19. Disable Apple Intelligence Notes Transcription

Apple Intelligence features such as Notes Transcription that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowNotesTranscription').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowNotesTranscription</key>
<false/>
```

ID	os_notes_transcription_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95238-2

7.20. Disable Apple Intelligence Notes Transcription Summary

Apple Intelligence features such as Notes Transcription Summary that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
```

```
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowNotesTranscriptionSummary').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowNotesTranscriptionSummary</key>
<false/>
```

ID	os_notes_transcription_summary_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95239-0

7.21. Enforce On Device Dictation

Dictation *MUST* be restricted to on device only to prevent potential data exfiltration.

The information system *MUST* be configured to provide only essential capabilities.



This rule only applies to Apple Silicon devices.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('forceOnDeviceOnlyDictation').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>forceOnDeviceOnlyDictation</key>
<true/>
```

ID	os_on_device_dictation_enforce	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95247-3

7.22. Remove Password Hint From User Accounts

User accounts *MUST* not contain password hints.

To check the state of the system, run the following command(s):

```
HINT=$( /usr/bin/dscl . -list /Users hint | /usr/bin/awk '{ print $2 }' )

if [ -z "$HINT" ]; then
    echo "PASS"
else
    echo "FAIL"
fi
```

If the result is not **PASS**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
for u in $( /usr/bin/dscl . -list /Users UniqueID | /usr/bin/awk '$2 > 500 {print $1}' ); do
    /usr/bin/dscl . -delete /Users/$u hint
done
```

ID	os_password_hint_remove	
References	800-53r5	• IA-6
	CCE	• CCE-95250-7

7.23. Disable Photos Enhanced Visual Search

Enhanced Visual Search *MUST* be disabled in the Photos app.

The information system *MUST* be configured to provide only essential capabilities. Disabling Enhanced Visual Search will mitigate the risk of unwanted data being sent to Apple.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.photos.shareddefaults')\
.objectForKey('IPXDefaultEnhancedVisualSearchEnabled').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.photos.shareddefaults) payload type:

```
<key>IPXDefaultEnhancedVisualSearchEnabled</key>
<false/>
```

ID	os_photos_enhanced_search_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95254-9

7.24. Disable Root Login

To assure individual accountability and prevent unauthorized access, logging in as root at the login window *MUST* be disabled.

The macOS system *MUST* require individuals to be authenticated with an individual authenticator prior to using a group authenticator, and administrator users *MUST* never log in directly as root.

To check the state of the system, run the following command(s):

```
/usr/bin/dscl . -read /Users/root UserShell 2>&1 | /usr/bin/grep -c "/usr/bin/false"
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/dscl . -create /Users/root UserShell /usr/bin/false
```

ID	os_root_disable	
References	800-53r5	• IA-2, IA-2(5)
	CCE	• CCE-95282-0

7.25. Ensure Advertising Privacy Protection in Safari Is Enabled

Allow privacy-preserving measurement of ad effectiveness *MUST* be enabled in Safari.

To check the state of the system, run the following command(s):

```
/usr/bin/profiles -P -o stdout | /usr/bin/grep -c  
'"WebKitPreferences.privateClickMeasurementEnabled" = 1' | /usr/bin/awk '{ if ($1 >=  
1) {print "1"} else {print "0"}}'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.Safari) payload type:

```
<key>WebKitPreferences.privateClickMeasurementEnabled</key>  
<true/>
```

ID	os_safari_advertising_privacy_protection_enable
----	---

References	800-53r5	• N/A
	CCE	• CCE-95283-8

7.26. Disable Automatic Opening of Safe Files in Safari

Open "safe" files after downloading *MUST* be disabled in Safari.

To check the state of the system, run the following command(s):

```
/usr/bin/profiles -P -o stdout | /usr/bin/grep -c 'AutoOpenSafeDownloads = 0' |
/usr/bin/awk '{ if ($1 >= 1) {print "1"} else {print "0"}}'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.Safari) payload type:

```
<key>AutoOpenSafeDownloads</key>
<false/>
```

ID	os_safari_open_safe_downloads_disable	
References	800-53r5	• N/A
	CCE	• CCE-95284-6

7.27. Ensure Prevent Cross-site Tracking in Safari Is Enabled

Prevent cross-site tracking *MUST* be enabled in Safari.

To check the state of the system, run the following command(s):

```
/usr/bin/profiles -P -o stdout | /usr/bin/grep -cE
'"WebKitPreferences.storageBlockingPolicy" = 1|"WebKitStorageBlockingPolicy" =
1|"BlockStoragePolicy" =2' | /usr/bin/awk '{ if ($1 >= 1) {print "1"} else {print
"0"}}'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.Safari) payload type:

```
<key>WebKitPreferences.storageBlockingPolicy</key>
<integer>1</integer>
<key>WebKitStorageBlockingPolicy</key>
<integer>1</integer>
<key>BlockStoragePolicy</key>
<integer>2</integer>
```

ID	os_safari_prevent_cross-site_tracking_enable	
References	800-53r5	• N/A
	CCE	• CCE-95285-3

7.28. Disable Apple Intelligence Safari Reader Summary

Apple Intelligence features such as Safari Reader Summary that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowSafariSummary').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowSafariSummary</key>
<false/>
```

ID	os_safari_reader_summary_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95286-1

7.29. Ensure Show Safari shows the Status Bar is Enabled

Safari *MUST* be configured to show the status bar.

To check the state of the system, run the following command(s):

```
/usr/bin/profiles -P -o stdout | /usr/bin/grep -c 'ShowOverlayStatusBar = 1' |
/usr/bin/awk '{ if ($1 >= 1) {print "1"} else {print "0"}}'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.Safari) payload type:

```
<key>ShowOverlayStatusBar</key>
<true/>
```

ID	os_safari_show_status_bar_enabled	
References	800-53r5	• N/A
	CCE	• CCE-95288-7

7.30. Ensure Warn When Visiting A Fraudulent Website in Safari Is Enabled

Warn when visiting a fraudulent website *MUST* be enabled in Safari.

To check the state of the system, run the following command(s):

```
/usr/bin/profiles -P -o stdout | /usr/bin/grep -c 'WarnAboutFraudulentWebsites = 1' |
```

```
/usr/bin/awk '{ if ($1 >= 1) {print "1"} else {print "0"}}'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.Safari) payload type:

```
<key>WarnAboutFraudulentWebsites</key>
<true/>
```

ID	os_safari_warn_fraudulent_website_enable	
References	800-53r5	• N/A
	CCE	• CCE-95289-5

7.31. Ensure Secure Boot Level Set to Full

The Secure Boot security setting *MUST* be set to full.

Full security is the default Secure Boot setting in macOS. During startup, when Secure Boot is set to full security, the Mac will verify the integrity of the operating system before allowing the operating system to boot.



This will only return a proper result on a T2 or Apple Silicon Macs.

To check the state of the system, run the following command(s):

```
/usr/libexec/mdmclient QuerySecurityInfo 2>/dev/null | /usr/bin/grep -c
"SecureBootLevel = full"
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:



Boot into Recovery Mode and enable Full Secure Boot

ID	os_secure_boot_verify
-----------	-----------------------

References	800-53r5	• SI-6 • SI-7, SI-7(1), SI-7(5)
	CCE	• CCE-95292-9

7.32. Ensure System Integrity Protection is Enabled

System Integrity Protection (SIP) *MUST* be enabled.

SIP is vital to protecting the integrity of the system as it prevents malicious users and software from making unauthorized and/or unintended modifications to protected files and folders; ensures the presence of an audit record generation capability for defined auditable events for all operating system components; protects audit tools from unauthorized access, modification, and deletion; restricts the root user account and limits the actions that the root user can perform on protected parts of the macOS; and prevents non-privileged users from granting other users direct access to the contents of their home directories and folders.



SIP is enabled by default in macOS.

To check the state of the system, run the following command(s):

```
/usr/bin/csrutil status | /usr/bin/grep -c 'System Integrity Protection status: enabled.'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/csrutil enable
```

To re-enable "System Integrity Protection", boot the affected system into "Recovery" mode, launch "Terminal" from the "Utilities" menu, and run the command.

ID	os_sip_enable
----	---------------

References	800-53r5	• AC-3 • AU-9, AU-9(3) • CM-5, CM-5(6) • SC-4 • SI-2 • SI-7
	CCE	• CCE-95298-6

7.33. Ensure Sleep and Display Sleep Is Enabled on Apple Silicon Devices

Apple Silicon MacBooks should set sleep timeout to 15 minutes (900 seconds) or less and the display sleep timeout should be 10 minutes (600 seconds) or less but less than the sleep setting.

To check the state of the system, run the following command(s):

```
error_count=0
if /usr/sbin/system_profiler SPHardwareDataType | /usr/bin/grep -q "MacBook"; then
    cpuType=$(/usr/sbin/sysctl -n machdep.cpu.brand_string)
    if echo "$cpuType" | grep -q "Apple"; then
        sleepMode=$(/usr/bin/pmset -b -g | /usr/bin/grep '^s*sleep' 2>&1 | /usr/bin/awk
'{print $2}')
        displaysleepMode=$(/usr/bin/pmset -b -g | /usr/bin/grep displaysleep 2>&1 |
/usr/bin/awk '{print $2}')
        if [[ "$sleepMode" == "" ]] || [[ "$sleepMode" -gt 15 ]]; then
            ((error_count++))
        fi
        if [[ "$displaysleepMode" == "" ]] || [[ "$displaysleepMode" -gt 10 ]] || [[
"$displaysleepMode" -gt "$sleepMode" ]]; then
            ((error_count++))
        fi
    fi
fi
echo "$error_count"
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/pmset -a sleep 15
/usr/bin/pmset -a displaysleep 10
```

ID	os_sleep_and_display_sleep_apple_silicon_enable	
References	800-53r5	• N/A
	CCE	• CCE-95302-6

7.34. Enforce Software Update App Update Updates Automatically

Software Update *MUST* be configured to enforce automatic updates of App Updates is enabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SoftwareUpdate')\
.objectForKey('AutomaticallyInstallAppUpdates').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SoftwareUpdate) payload type:

```
<key>AutomaticallyInstallAppUpdates</key>
<true/>
```

ID	os_software_update_app_update_enforce	
References	800-53r5	• N/A
	CCE	• CCE-95402-4

7.35. Configure Sudo To Log Events

Sudo *MUST* be configured to log privilege escalation.

To check the state of the system, run the following command(s):

```
/usr/bin/sudo /usr/bin/sudo -V | /usr/bin/grep -c "Log when a command is allowed by
sudoers"
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/find /etc/sudoers* -type f -exec sed -i ''  
'/^Defaults[[:blank:]]*!\log_allowed/s/^/# /' '{}' \;  
/bin/echo "Defaults log_allowed" >> /etc/sudoers.d/mscp
```

ID	os_sudo_log_enforce	
References	800-53r5	• AC-6(9)
	CCE	• CCE-95316-6

7.36. Configure Sudo Timeout Period to 0

The file /etc/sudoers *MUST* include a timestamp_timeout of 0.

To check the state of the system, run the following command(s):

```
/usr/bin/sudo /usr/bin/sudo -V | /usr/bin/grep -c "Authentication timestamp timeout:  
0.0 minutes"
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/find /etc/sudoers* -type f -exec sed -i '' '/timestamp_timeout/d' '{}' \;  
/bin/echo "Defaults timestamp_timeout=0" >> /etc/sudoers.d/mscp  
/bin/chmod 440 /etc/sudoers.d/mscp
```

ID	os_sudo_timeout_configure	
References	800-53r5	• N/A
	CCE	• CCE-95317-4

7.37. Configure Sudoers Timestamp Type

The file /etc/sudoers *MUST* be configured to not include a timestamp_type of global or ppid and be

configured for timestamp record types of tty.

This rule ensures that the "sudo" command will prompt for the administrator's password at least once in each newly opened terminal window. This prevents a malicious user from taking advantage of an unlocked computer or an abandoned logon session by bypassing the normal password prompt requirement.

To check the state of the system, run the following command(s):

```
/usr/bin/sudo /usr/bin/sudo -V | /usr/bin/awk -F": " ' /Type of authentication
timestamp record/{print $2}'
```

If the result is not **tty**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/find /etc/sudoers* -type f -exec sed -i '' '/timestamp_type/d;
/!tty_tickets/d' '{} ' \;
```

ID	os_sudoers_timestamp_type_configure	
References	800-53r5	• CM-5(1) • IA-11
	CCE	• CCE-95318-2

7.38. Ensure System Volume is Read Only

The System volume *MUST* be mounted as read-only in order to ensure that configurations critical to the integrity of the macOS have not been compromised. System Integrity Protection (SIP) will prevent the system volume from being mounted as writable.



The system volume is read only by default in macOS.

To check the state of the system, run the following command(s):

```
/usr/sbin/system_profiler SPStorageDataType | /usr/bin/awk '/Mount Point:
\\$/{x=NR+2}(NR==x){print $2}'
```

If the result is not **No**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:



To remount the System volume as Read Only, rebooting the computer will mount it as Read Only.

ID	os_system_read_only	
References	800-53r5	• MA-4(1) • SC-34 • SI-7
	CCE	• CCE-95319-0

7.39. Ensure Appropriate Permissions Are Enabled for System Wide Applications

Applications in the System Applications Directory (/Applications) *MUST* not be world-writable.

To check the state of the system, run the following command(s):

```
/usr/bin/find /Applications -iname "*\.app" -type d -perm -2 -ls | /usr/bin/wc -l |  
/usr/bin/xargs
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
IFS=$'\n'  
for apps in $( /usr/bin/find /Applications -iname "*\.app" -type d -perm -2 ); do  
  /bin/chmod -R o-w "$apps"  
done
```

ID	os_system_wide_applications_configure	
References	800-53r5	• N/A
	CCE	• CCE-95320-8

7.40. Ensure Secure Keyboard Entry Terminal.app is Enabled

Secure keyboard entry *MUST* be enabled in Terminal.app.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.Terminal')\
.objectForKey('SecureKeyboardEntry').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.Terminal) payload type:

```
<key>SecureKeyboardEntry</key>
<true/>
```

ID	os_terminal_secure_keyboard_enable	
References	800-53r5	• N/A
	CCE	• CCE-95321-6

7.41. Disable Trivial File Transfer Protocol Service

If the system does not require Trivial File Transfer Protocol (TFTP), support it is non-essential and *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling TFTP helps prevent the unauthorized connection of devices and the unauthorized transfer of information.



TFTP service is disabled at startup by default macOS.

To check the state of the system, run the following command(s):

```
result="FAIL"
enabled=$(/bin/launchctl print-disabled system | /usr/bin/grep '"com.apple.tftpd" =>
```

```

enabled')
running=$(/bin/launchctl print system/com.apple.tftpd 2>/dev/null)

if [[ -z "$running" ]] && [[ -z "$enabled" ]]; then
    result="PASS"
elif [[ -n "$running" ]]; then
    result=result+ " RUNNING"
elif [[ -n "$enabled" ]]; then
    result=result+ " ENABLED"
fi
echo $result

```

If the result is not **PASS**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```

/bin/launchctl bootout system/com.apple.tftpd
/bin/launchctl disable system/com.apple.tftpd

```

The system may need to be restarted for the update to take effect.

ID	os_tftpd_disable	
References	800-53r5	• AC-17 • AC-3 • IA-5(1)
	CCE	• CCE-95323-2

7.42. Enable Time Synchronization Daemon

The macOS time synchronization daemon (timed) *MUST* be enabled for proper time synchronization to an authorized time server.



The time synchronization daemon is enabled by default on macOS.

To check the state of the system, run the following command(s):

```

/bin/launchctl print system | /usr/bin/grep -c -E '\tcom.apple.timed'

```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/launchctl load -w /System/Library/LaunchDaemons/com.apple.timed.plist
```



The service **timed** cannot be unloaded or loaded while System Integrity Protection (SIP) is enabled.

ID	os_time_server_enabled	
References	800-53r5	• AU-12(1) • SC-45(1)
	CCE	• CCE-95325-7

7.43. Disable Login to Other User's Active and Locked Sessions

The ability to log in to another user's active or locked session *MUST* be disabled.

macOS has a privilege that can be granted to any user that will allow that user to unlock active user's sessions. Disabling the admins and/or user's ability to log into another user's active and locked session prevents unauthorized persons from viewing potentially sensitive and/or personal information.



Configuring this setting will change the user experience and disable TouchID from unlocking the screensaver. A configuration profile will be generated to include the setting that restores the expected behavior. You can also apply the settings using `/usr/bin/sudo /usr/bin/defaults write /Library/Preferences/com.apple.loginwindow screenUnlockMode -int 1`.



Do not apply this rule if your organization uses smartcards and Platform Single Sign-On (PSSO).

To check the state of the system, run the following command(s):

```
RESULT="FAIL"
SS_RULE=$(/usr/bin/security -q authorizationdb read system.login.screensaver 2>&1 |
/usr/bin/xmllint --xpath "//dict/key[.='rule']/following-
sibling::array[1]/string/text()" -)

if [[ "${SS_RULE}" == "authenticate-session-owner" ]]; then
    RESULT="PASS"
else
```

```
PSSO_CHECK=$(/usr/bin/security -q authorizationdb read "$SS_RULE" 2>&1 |
/usr/bin/xmllint --xpath '//key[.="rule"]/following-sibling::array[1]/string/text()' -
)
if /usr/bin/grep -Fxq "authenticate-session-owner" <<<"$PSSO_CHECK"; then
    RESULT="PASS"
fi
fi

echo $RESULT
```

If the result is not **PASS**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.loginwindow) payload type:

```
<key>screenUnlockMode</key>
<integer>1</integer>
```

ID	os_unlock_active_user_session_disable	
References	800-53r5	• IA-2, IA-2(5)
	CCE	• CCE-95328-1

7.44. Disable Unix-to-Unix Copy Protocol Service

The system *MUST* not have the Unix-to-Unix Copy Protocol (UUCP) service active.

UUCP, a set of programs that enable the sending of files between different UNIX systems as well as sending commands to be executed on another system, is not essential and *MUST* be disabled in order to prevent the unauthorized connection of devices, transfer of information, and tunneling.



UUCP service is disabled at startup by default macOS.

To check the state of the system, run the following command(s):

```
result="FAIL"
enabled=$(/bin/launchctl print-disabled system | /usr/bin/grep '"com.apple.uucp" =>
enabled')
running=$(/bin/launchctl print system/com.apple.uucp 2>/dev/null)

if [[ -z "$running" ]] && [[ -z "$enabled" ]]; then
    result="PASS"
```

```

elif [[ -n "$running" ]]; then
    result=result+" RUNNING"
elif [[ -n "$enabled" ]]; then
    result=result+" ENABLED"
fi
echo $result

```

If the result is not **PASS**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```

/bin/launchctl bootout system/com.apple.uucp
/bin/launchctl disable system/com.apple.uucp

```

The system may need to be restarted for the update to take effect.

ID	os_uucp_disable	
References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95330-7

7.45. Ensure No World Writable Files Exist in the Library Folder

Folders in /System/Volumes/Data/Library *MUST* not be world-writable.



Some vendors are known to create world-writable folders to the System Library folder. You may need to add more exclusions to this check and fix to match your environment.

To check the state of the system, run the following command(s):

```

/usr/bin/find /Library -type d -perm -002 ! -perm -1000 ! -xattrname
com.apple.rootless 2>/dev/null | /usr/bin/wc -l | /usr/bin/xargs

```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
IFS=$'\n'
for libPermissions in $(/usr/bin/find /Library -type d -perm -002 ! -perm -1000 !
-xattrname com.apple.rootless 2>/dev/null); do
  /bin/chmod -R o-w "$libPermissions"
done
```

ID	os_world_writable_library_folder_configure	
References	800-53r5	• N/A
	CCE	• CCE-95332-3

7.46. Ensure No World Writable Files Exist in the System Folder

Folders in /System/Volumes/Data/System *MUST* not be world-writable.

To check the state of the system, run the following command(s):

```
/usr/bin/find /System/Volumes/Data/System -type d -perm -2 -ls | /usr/bin/grep -vE
"downloadDir|locks" | /usr/bin/wc -l | /usr/bin/xargs
```

If the result is not 0, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
IFS=$'\n'
for sysPermissions in $( /usr/bin/find /System/Volumes/Data/System -type d -perm
-2 | /usr/bin/grep -vE "downloadDir|locks" ); do
  /bin/chmod -R o-w "$sysPermissions"
done
```

ID	os_world_writable_system_folder_configure	
References	800-53r5	• N/A
	CCE	• CCE-95333-1

7.47. Disable Apple Intelligence Writing Tools

Apple Intelligence features such as writing tools that use off device AI *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowWritingTools').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowWritingTools</key>
<false/>
```

ID	os_writing_tools_disable	
References	800-53r5	• AC-20, AC-20(1) • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95334-9

Chapter 8. Password Policy

This section contains the configuration and enforcement of settings pertaining to password policies in macOS.



The check/fix commands outlined in this section *MUST* be run by a user with elevated privileges.



The password policy recommendations in the NIST 800-53 (Rev 5) and NIST 800-63B state that complexity rules should be organizationally defined. The values defined are based off of common complexity values. But your organization may define its own password complexity rules.



The settings outlined in this section adhere to the recommendations provided in this document for systems that utilize passwords for local accounts. If systems are integrated with a directory service, local password policies should align with domain password policies to the fullest extent feasible.

8.1. Limit Consecutive Failed Login Attempts to 5

The macOS *MUST* be configured to limit the number of failed login attempts to a maximum of 5. When the maximum number of failed attempts is reached, the account *MUST* be locked for a period of time after.

This rule protects against malicious users attempting to gain access to the system via brute-force hacking methods.

To check the state of the system, run the following command(s):

```
/usr/bin/pwpolicy -getaccountpolicies 2> /dev/null | /usr/bin/tail +2 |  
/usr/bin/xmllint --xpath  
'//dict/key[text()="policyAttributeMaximumFailedAuthentications"]/following-  
sibling::integer[1]/text()' - | /usr/bin/awk '{ if ($1 <= 5) {print "pass"} else  
{print "fail"}}' | /usr/bin/uniq
```

If the result is not **pass**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.mobiledevice.passwordpolicy) payload type:

```
<key>maxFailedAttempts</key>
```

```
<integer>5</integer>
```

ID	pwpolicy_account_lockout_enforce	
References	800-53r5	• AC-7
	CCE	• CCE-95337-2

8.2. Set Account Lockout Time to 15 Minutes

The macOS *MUST* be configured to enforce a lockout time period of at least 15 minutes when the maximum number of failed logon attempts is reached.

This rule protects against malicious users attempting to gain access to the system via brute-force hacking methods.

To check the state of the system, run the following command(s):

```
/usr/bin/pwpolicy -getaccountpolicies 2> /dev/null | /usr/bin/tail +2 |  
/usr/bin/xmllint --xpath '//dict/key[text()="autoEnableInSeconds"]/following-  
sibling::integer[1]/text()' - | /usr/bin/awk '{ if ($1/60 >= 15 ) {print "pass"} else  
{print "fail"}}' | /usr/bin/uniq
```

If the result is not **pass**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.mobiledevice.passwordpolicy) payload type:

```
<key>minutesUntilFailedLoginReset</key>  
<integer>15</integer>
```

ID	pwpolicy_account_lockout_timeout_enforce	
References	800-53r5	• AC-7
	CCE	• CCE-95338-0

8.3. Require Passwords Contain a Minimum of One Numeric Character

The macOS *MUST* be configured to require at least one numeric character be used when a password is created.

This rule enforces password complexity by requiring users to set passwords that are less vulnerable to malicious users.



To comply with Executive Order 14028, “Improving the Nation’s Cybersecurity”, OMB M-22-09, “Moving the U.S. Government Toward Zero Trust Cybersecurity Principles”, and NIST SP-800-63b, “Digital Identity Guidelines: Authentication and Lifecycle Management” federal, military, and intelligence communities must adopt the following configuration settings. Password policies must not require the use of complexity policies such as upper characters, lower characters, or special characters. Password policies must also not require the use of regular rotation. Password policies should define a minimum length. Multifactor authentication should be used where ever possible.

To check the state of the system, run the following command(s):

```
/usr/bin/pwpolicy -getaccountpolicies 2> /dev/null | /usr/bin/tail +2 |  
/usr/bin/xmllint --xpath '//dict/key[text()="policyIdentifier"]/following-  
sibling::*[1]/text()' - | /usr/bin/grep "requireAlphanumeric" -c
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.mobiledevice.passwordpolicy) payload type:

```
<key>requireAlphanumeric</key>  
<true/>
```

ID	pwpolicy_alpha_numeric_enforce	
References	800-53r5	• IA-5(1)
	CCE	• CCE-95339-8

8.4. Require a Minimum Password Length of 15 Characters

The macOS *MUST* be configured to require a minimum of 15 characters be used when a password is created.

This rule enforces password complexity by requiring users to set passwords that are less vulnerable to malicious users.



To comply with Executive Order 14028, “Improving the Nation’s Cybersecurity”, OMB M-22-09, “Moving the U.S. Government Toward Zero Trust Cybersecurity Principles”, and NIST SP-800-63b, “Digital Identity Guidelines: Authentication and Lifecycle Management” federal, military, and intelligence communities must adopt the following configuration settings. Password policies must not require the use of complexity policies such as upper characters, lower characters, or special characters. Password policies must also not require the use of regular rotation. Password policies should define a minimum length. Multifactor authentication should be used where ever possible.

To check the state of the system, run the following command(s):

```
/usr/bin/pwpolicy -getaccountpolicies 2>/dev/null | tail +2 | grep -oE
"policyAttributePassword matches '.*\{[0-9]+\",' | awk -F'[,]' -v ODV=15 '{if ($2 > max)
max=$2} END {print (max >= ODV) ? "pass" : "fail"}'
```

If the result is not **pass**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.mobiledevice.passwordpolicy) payload type:

```
<key>minLength</key>
<integer>15</integer>
```

ID	pwpolicy_minimum_length_enforce	
References	800-53r5	• IA-5(1)
	CCE	• CCE-95346-3

8.5. Prohibit Repeating, Ascending, and Descending Character Sequences

The macOS *MUST* be configured to prohibit the use of repeating, ascending, and descending character sequences when a password is created.

This rule enforces password complexity by requiring users to set passwords that are less vulnerable to malicious users.



To comply with Executive Order 14028, “Improving the Nation’s Cybersecurity”, OMB M-22-09, “Moving the U.S. Government Toward Zero Trust Cybersecurity Principles”, and NIST SP-800-63b, “Digital Identity Guidelines: Authentication and Lifecycle Management” federal, military, and intelligence communities must adopt the following configuration settings. Password policies must not require the use of complexity policies such as upper characters, lower characters, or special characters. Password policies must also not require the use of regular rotation. Password policies should define a minimum length. Multifactor authentication should be used where ever possible.



pwpolicy_simple_sequence_disable prevents use of passwords which are regularly found in compromised password lists.

To check the state of the system, run the following command(s):

```
/usr/bin/pwpolicy -getaccountpolicies 2> /dev/null | /usr/bin/tail +2 |
/usr/bin/xmllint --xpath '//dict/key[text()="policyIdentifier"]/following-
sibling::*[1]/text()' - | /usr/bin/grep "allowSimple" -c
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.mobiledevice.passwordpolicy) payload type:

```
<key>allowSimple</key>
<false/>
```

ID	pwpolicy_simple_sequence_disable	
References	800-53r5	• IA-5(1)
	CCE	• CCE-95349-7

8.6. Require Passwords Contain a Minimum of One Special Character

The macOS *MUST* be configured to require at least one special character be used when a password is created.

Special characters are those characters that are not alphanumeric. Examples include: ~ ! @ # \$ % ^ * .

This rule enforces password complexity by requiring users to set passwords that are less vulnerable to malicious users.



To comply with Executive Order 14028, “Improving the Nation’s Cybersecurity”, OMB M-22-09, “Moving the U.S. Government Toward Zero Trust Cybersecurity Principles”, and NIST SP-800-63b, “Digital Identity Guidelines: Authentication and Lifecycle Management” federal, military, and intelligence communities must adopt the following configuration settings. Password policies must not require the use of complexity policies such as upper characters, lower characters, or special characters. Password policies must also not require the use of regular rotation. Password policies should define a minimum length. Multifactor authentication should be used where ever possible.

To check the state of the system, run the following command(s):

```
/usr/bin/pwpolicy -getaccountpolicies 2>/dev/null | /usr/bin/tail -n +2 |  
/usr/bin/xmllint --xpath "//string[contains(text(), \"policyAttributePassword matches  
'(.*[a-zA-Z0-9].*){\\\"}]\" - 2>/dev/null | /usr/bin/awk -F\"{\" '{if ($2 >= 1) {print  
\"pass\"} else {print \"fail\"}}'
```

If the result is not **pass**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.mobiledevice.passwordpolicy) payload type:

```
<key>minComplexChars</key>  
<integer>1</integer>
```

ID

pwpolicy_special_character_enforce

References	800-53r5	• IA-5(1)
	CCE	• CCE-95350-5

Chapter 9. System Settings

This section contains the configuration and enforcement of the settings within the macOS System Settings application.



The check/fix commands outlined in this section *MUST* be run by a user with elevated privileges.

9.1. Prevent Apple Watch from Terminating a Session Lock

Apple Watches are not an approved authenticator and their use *MUST* be disabled.

Disabling Apple watches is a necessary step to ensuring that the information system retains a session lock until the user reestablishes access using an authorized identification and authentication procedures.



Unlocking the system with an Apple Watch is not an approved authenticator for US Federal Government usage as it has not been verified to meet the strength requirements outlined in NIST SP 800-63.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowAutoUnlock').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowAutoUnlock</key>
<false/>
```

ID	system_settings_apple_watch_unlock_disable
----	--

References	800-53r5	• IA-5
	CCE	• CCE-95355-4

9.2. Disable Unattended or Automatic Logon to the System

Automatic logon *MUST* be disabled.

When automatic logons are enabled, the default user account is automatically logged on at boot time without prompting the user for a password. Even if the screen is later locked, a malicious user would be able to reboot the computer and find it already logged in. Disabling automatic logons mitigates this risk.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.loginwindow')\
.objectForKey('com.apple.login.mcx.DisableAutoLoginClient').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.loginwindow) payload type:

```
<key>com.apple.login.mcx.DisableAutoLoginClient</key>
<true/>
```

ID	system_settings_automatic_login_disable	
References	800-53r5	• IA-2 • IA-5(13)
	CCE	• CCE-95356-2

9.3. Disable Content Caching Service

Content caching *MUST* be disabled.

Content caching is a macOS service that helps reduce Internet data usage and speed up software

installation on Mac computers. It is not recommended for devices furnished to employees to act as a caching server.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowContentCaching').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowContentCaching</key>
<false/>
```

ID	system_settings_content_caching_disable	
References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95362-0

9.4. Enforce Critical Security Updates to be Installed

Ensure that security updates are installed as soon as they are available from Apple.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SoftwareUpdate')\
.objectForKey('CriticalUpdateInstall').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SoftwareUpdate) payload type:

```
<key>CriticalUpdateInstall</key>
<true/>
```

ID	system_settings_critical_update_install_enforce	
References	800-53r5	• SI-2
	CCE	• CCE-95363-8

9.5. Disable Sending Diagnostic and Usage Data to Apple

The ability to submit diagnostic data to Apple *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling the submission of diagnostic and usage information will mitigate the risk of unwanted data being sent to Apple.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
let pref1 = $.NSUserDefaults.alloc.initWithSuiteName('com.apple.SubmitDiagInfo')\
.objectForKey('AutoSubmit').js
let pref2 = $.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowDiagnosticSubmission').js
if ( pref1 == false && pref2 == false ){
    return("true")
} else {
    return("false")
}
}
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SubmitDiagInfo) payload type:

```
<key>AutoSubmit</key>
<false/>
```

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowDiagnosticSubmission</key>
<false/>
```

ID	system_settings_diagnostics_reports_disable	
References	800-53r5	• AC-20 • SC-7(10) • SI-11
	CCE	• CCE-95364-6

9.6. Disable External Intelligence Integrations

Integration with external intelligence systems *MUST* be disabled unless approved by the organization. Disabling external intelligence integration will mitigate the risk of data being sent to unapproved third party.

The information system *MUST* be configured to provide only essential capabilities.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowExternalIntelligenceIntegrations').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowExternalIntelligenceIntegrations</key>
<false/>
```

ID	system_settings_external_intelligence_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1)
	CCE	• CCE-95365-3

9.7. Disable External Intelligence Integration Sign In

The ability to sign into an external intelligence systems *MUST* be disabled unless approved by the organization. Disabling external intelligence integration will mitigate the risk of data being sent to unapproved third party.

The information system *MUST* be configured to provide only essential capabilities.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowExternalIntelligenceIntegrationsSignIn').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowExternalIntelligenceIntegrationsSignIn</key>
<false/>
```

ID	system_settings_external_intelligence_sign_in_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1)
	CCE	• CCE-95366-1

9.8. Enforce FileVault

FileVault *MUST* be enforced.

The information system implements cryptographic mechanisms to protect the confidentiality and

integrity of information stored on digital media during transport outside of controlled areas.



See the FileVault supplemental to implement this rule.

To check the state of the system, run the following command(s):

```
dontAllowDisable=$(/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.MCX')\
.objectForKey('dontAllowFDEDisable').js
EOS
)
fileVault=$(/usr/bin/fdesetup status | /usr/bin/grep -c "FileVault is On.")
if [[ "$dontAllowDisable" == "true" ]] && [[ "$fileVault" == 1 ]]; then
    echo "1"
else
    echo "0"
fi
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.MCX) payload type:

```
<key>dontAllowFDEDisable</key>
<true/>
```

ID	system_settings_filevault_enforce	
References	800-53r5	• SC-28, SC-28(1)
	CCE	• CCE-95367-9

9.9. Enable macOS Application Firewall

The macOS Application Firewall is the built-in firewall that comes with macOS, and it *MUST* be enabled.

When the macOS Application Firewall is enabled, the flow of information within the information system and between interconnected systems will be controlled by approved authorizations.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.security.firewall')\
.objectForKey('EnableFirewall').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.security.firewall) payload type:

```
<key>EnableFirewall</key>
<true/>
```

ID	system_settings_firewall_enable	
References	800-53r5	• AC-4 • CM-7, CM-7(1) • SC-7, SC-7(12)
	CCE	• CCE-95369-5

9.10. Enable Firewall Stealth Mode

Firewall Stealth Mode *MUST* be enabled.

When stealth mode is enabled, the Mac will not respond to any probing requests, and only requests from authorized applications will still be authorized.



Enabling firewall stealth mode may prevent certain remote mechanisms used for maintenance and compliance scanning from properly functioning. Information System Security Officers (ISSOs) are advised to first fully weigh the potential risks posed to their organization before opting not to enable stealth mode.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.security.firewall')\
.objectForKey('EnableStealthMode').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.security.firewall) payload type:

```
<key>EnableStealthMode</key>
<true/>
<key>EnableFirewall</key>
<true/>
```

ID	system_settings_firewall_stealth_mode_enable	
References	800-53r5	• CM-7, CM-7(1) • SC-7, SC-7(16)
	CCE	• CCE-95370-3

9.11. Apply Gatekeeper Settings to Block Applications from Unidentified Developers

The information system implements cryptographic mechanisms to authenticate software prior to installation.

Gatekeeper settings must be configured correctly to only allow the system to run applications downloaded from the Mac App Store or applications signed with a valid Apple Developer ID code. Administrator users will still have the option to override these settings on a per-app basis. Gatekeeper is a security feature that ensures that applications must be digitally signed by an Apple-issued certificate in order to run. Digital signatures allow the macOS to verify that the application has not been modified by a malicious third party.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
  let pref1 = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.systempolicy.control')\
.objectForKey('AllowIdentifiedDevelopers'))
  let pref2 = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.systempolicy.control')\
.objectForKey('EnableAssessment'))
  if ( pref1 == true && pref2 == true ) {
    return("true")
  }
}
```



```

    } else {
        return("false")
    }
}
EOS

```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.systempolicy.control) payload type:

```

<key>AllowIdentifiedDevelopers</key>
<true/>
<key>EnableAssessment</key>
<true/>

```

ID	system_settings_gatekeeper_identified_developers_allowed	
References	800-53r5	• CM-14 • CM-5 • SI-7(1), SI-7(15)
	CCE	• CCE-95371-1

9.12. Configure Gatekeeper to Disallow End User Override

Gatekeeper *MUST* be configured with a configuration profile to prevent normal users from overriding its settings.

If users are allowed to disable Gatekeeper or set it to a less restrictive setting, malware could be introduced into the system.

To check the state of the system, run the following command(s):

```

/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.systempolicy.managed')\
.objectForKey('DisableOverride').js
EOS

```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.systempolicy.managed) payload type:

```
<key>DisableOverride</key>
<true/>
```

ID	system_settings_gatekeeper_override_disallow	
References	800-53r5	• CM-5 • SI-7(15)
	CCE	• CCE-95372-9

9.13. Disable Guest Access to Shared SMB Folders

Guest access to shared Server Message Block (SMB) folders *MUST* be disabled.

Turning off guest access prevents anonymous users from accessing files shared via SMB.

To check the state of the system, run the following command(s):

```
/usr/bin/defaults read /Library/Preferences/SystemConfiguration/com.apple.smb.server
AllowGuestAccess
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/sysadminctl -smbGuestAccess off
```

ID	system_settings_guest_access_smb_disable	
References	800-53r5	• AC-2, AC-2(9)
	CCE	• CCE-95373-7

9.14. Disable the Guest Account

Guest access *MUST* be disabled.

Turning off guest access prevents anonymous users from accessing files.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
  let pref1 = ObjC.unwrap($.NSUserDefaults.alloc.initWithSuiteName('com.apple.MCX')\
.objectForKey('DisableGuestAccount'))
  let pref2 = ObjC.unwrap($.NSUserDefaults.alloc.initWithSuiteName('com.apple.MCX')\
.objectForKey('EnableGuestAccount'))
  if ( pref1 == true && pref2 == false ) {
    return("true")
  } else {
    return("false")
  }
}
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.MCX) payload type:

```
<key>DisableGuestAccount</key>
<true/>
<key>EnableGuestAccount</key>
<false/>
```

ID	system_settings_guest_account_disable	
References	800-53r5	• AC-2, AC-2(9)
	CCE	• CCE-95374-5

9.15. Secure Hot Corners

Hot corners *MUST* be secured.

The information system conceals, via the session lock, information previously visible on the display

with a publicly viewable image. Although hot corners can be used to initiate a session lock or to launch useful applications, they can also be configured to disable an automatic session lock from initiating. Such a configuration introduces the risk that a user might forget to manually lock the screen before stepping away from the computer.



The check and fix are for the last logged in user. To get the last logged in user, run the following.

```
CURRENT_USER=$( /usr/bin/defaults read
/Library/Preferences/com.apple.loginwindow lastUserName )
```

To check the state of the system, run the following command(s):

```
bl_corner="$(/usr/bin/defaults read /Users/"$CURRENT_USER
/Library/Preferences/com.apple.dock wvous-bl-corner 2>/dev/null)"
tl_corner="$(/usr/bin/defaults read /Users/"$CURRENT_USER
/Library/Preferences/com.apple.dock wvous-tl-corner 2>/dev/null)"
tr_corner="$(/usr/bin/defaults read /Users/"$CURRENT_USER
/Library/Preferences/com.apple.dock wvous-tr-corner 2>/dev/null)"
br_corner="$(/usr/bin/defaults read /Users/"$CURRENT_USER
/Library/Preferences/com.apple.dock wvous-br-corner 2>/dev/null)"

if [[ "$bl_corner" != "6" ]] && [[ "$tl_corner" != "6" ]] && [[ "$tr_corner" != "6" ]]
&& [[ "$br_corner" != "6" ]]; then
    echo "0"
fi
```

If the result is not 0, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/sudo -u "$CURRENT_USER" /usr/bin/defaults delete /Users/"$CURRENT_USER
/Library/Preferences/com.apple.dock wvous-bl-corner 2>/dev/null
/usr/bin/sudo -u "$CURRENT_USER" /usr/bin/defaults delete /Users/"$CURRENT_USER
/Library/Preferences/com.apple.dock wvous-tl-corner 2>/dev/null
/usr/bin/sudo -u "$CURRENT_USER" /usr/bin/defaults delete /Users/"$CURRENT_USER
/Library/Preferences/com.apple.dock wvous-tr-corner 2>/dev/null
/usr/bin/sudo -u "$CURRENT_USER" /usr/bin/defaults delete /Users/"$CURRENT_USER
/Library/Preferences/com.apple.dock wvous-br-corner 2>/dev/null
```

ID	system_settings_hot_corners_secure
----	------------------------------------

References	800-53r5	• AC-11(1)
	CCE	• CCE-95376-0

9.16. Disable Sending Audio Recordings and Transcripts to Apple

The ability for Apple to store and review audio of your audio recordings and transcripts of your vocal shortcuts and voice control interactions *MUST* be disabled. This will disable "Improve Assistive Voice Features" in Privacy & Security within System Settings.

The information system *MUST* be configured to provide only essential capabilities. Disabling the submission of this information will mitigate the risk of unwanted data being sent to Apple.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.Accessibility')\
.objectForKey('AXSAudioDonationSiriImprovementEnabled').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.Accessibility) payload type:

```
<key>AXSAudioDonationSiriImprovementEnabled</key>
<false/>
```

ID	system_settings_improve_assistive_voice_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95377-8

9.17. Disable Improve Search Information to Apple

Sending data to Apple to help improve search *MUST* be disabled. This will disable "Improve Search"

within Spotlight in System Settings.

The information system *MUST* be configured to provide only essential capabilities. Disabling the submission of search data will mitigate the risk of unwanted data being sent to Apple.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.assistant.support')\
.objectForKey('Search Queries Data Sharing Status').js
EOS
```

If the result is not 2, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.assistant.support) payload type:

```
<key>Search Queries Data Sharing Status</key>
<integer>2</integer>
```

ID	system_settings_improve_search_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95378-6

9.18. Disable Improve Siri and Dictation Information to Apple

The ability for Apple to store and review audio of your Siri and Dictation interactions *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling the submission of Siri and Dictation information will mitigate the risk of unwanted data being sent to Apple.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
```

```
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.assistant.support')\
.objectForKey('Siri Data Sharing Opt-In Status').js
EOS
```

If the result is not 2, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.assistant.support) payload type:

```
<key>Siri Data Sharing Opt-In Status</key>
<integer>2</integer>
```

ID	system_settings_improve_siri_dictation_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95379-4

9.19. Disable Internet Sharing

If the system does not require Internet sharing, support for it is non-essential and *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling Internet sharing helps prevent the unauthorized connection of devices, unauthorized transfer of information, and unauthorized tunneling.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.MCX')\
.objectForKey('forceInternetSharingOff').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.MCX) payload type:

```
<key>forceInternetSharingOff</key>
<true/>
```

ID	system_settings_internet_sharing_disable	
References	800-53r5	• AC-20 • AC-4
	CCE	• CCE-95382-8

9.20. Enable Location Services

Location Services *MUST* be enabled.

To check the state of the system, run the following command(s):

```
/usr/bin/sudo -u _locationd /usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.locationd')\
.objectForKey('LocationServicesEnabled').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/defaults write
/var/db/locationd/Library/Preferences/ByHost/com.apple.locationd
LocationServicesEnabled -bool true;
pid=$(/bin/launchctl print system | /usr/bin/awk '/\tcom.apple.locationd/ {print
$1}')
kill -9 $pid
```

ID	system_settings_location_services_enable	
References	800-53r5	• N/A
	CCE	• CCE-95384-4

9.21. Configure Login Window to Show A Custom Message

The login window *MUST* be configured to show a custom access warning message.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS | /usr/bin/base64
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.loginwindow')\
.objectForKey('LoginwindowText').js
EOS
```

If the result is not **Unauthorized access prohibited**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.loginwindow) payload type:

```
<key>LoginwindowText</key>
<string>Unauthorized access prohibited</string>
```

ID	system_settings_loginwindow_loginwindowtext_enable	
References	800-53r5	• N/A
	CCE	• CCE-95386-9

9.22. Disable Media Sharing

Media sharing *MUST* be disabled.

When Media Sharing is enabled, the computer starts a network listening service that shares the contents of the user’s music collection with other users in the same subnet.

The information system *MUST* be configured to provide only essential capabilities. Disabling Media Sharing helps prevent the unauthorized connection of devices and the unauthorized transfer of information. Disabling Media Sharing mitigates this risk.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
```

```

let pref1 = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowMediaSharing'))
let pref2 = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowMediaSharingModification'))
if ( pref1 == false && pref2 == false ) {
    return("true")
} else {
    return("false")
}
}
EOS

```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```

<key>allowMediaSharing</key>
<false/>
<key>allowMediaSharingModification</key>
<false/>

```

ID	system_settings_media_sharing_disabled	
References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95388-5

9.23. Disable Password Hints

Password hints *MUST* be disabled.

Password hints leak information about passwords that are currently in use and can lead to loss of confidentiality.

To check the state of the system, run the following command(s):

```

/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.loginwindow')\
.objectForKey('RetriesUntilHint').js

```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.loginwindow) payload type:

```
<key>RetriesUntilHint</key>
<integer>0</integer>
```

ID	system_settings_password_hints_disable	
References	800-53r5	• IA-6
	CCE	• CCE-95389-3

9.24. Disable Personalized Advertising

Ad tracking and targeted ads *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling ad tracking ensures that applications and advertisers are unable to track users' interests and deliver targeted advertisements.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowApplePersonalizedAdvertising').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowApplePersonalizedAdvertising</key>
```

<false/>

ID	system_settings_personalized_advertising_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95390-1

9.25. Disable Printer Sharing

Printer Sharing *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/sbin/cupsctl | /usr/bin/grep -c "_share_printers=0"
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/cupsctl --no-share-printers
/usr/bin/lpstat -p | awk '{print $2}' | /usr/bin/xargs -I{} lpadmin -p {} -o
printer-is-shared=false
```

ID	system_settings_printer_sharing_disable	
References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95391-9

9.26. Disable Remote Apple Events

If the system does not require Remote Apple Events, support for Apple Remote Events is non-essential and *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities. Disabling Remote Apple Events helps prevent the unauthorized connection of devices, the unauthorized transfer of information, and unauthorized tunneling.

To check the state of the system, run the following command(s):

```
/bin/launchctl print-disabled system | /usr/bin/grep -c '"com.apple.AEServer" => disabled'
```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/systemsetup -setremoteappleevents off  
/bin/launchctl disable system/com.apple.AEServer
```



Systemsetup with -setremoteappleevents flag will fail unless you grant Full Disk Access to systemsetup or its parent process. Requires supervision.

ID	system_settings_rae_disable	
References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95392-7

9.27. Disable Remote Management

Remote Management *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/libexec/mdmclient QuerySecurityInfo 2>/dev/null | /usr/bin/grep -c  
"RemoteDesktopEnabled = 0"
```

If the result is not **1**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/System/Library/CoreServices/RemoteManagement/ARDAgent.app/Contents/Resources/kick  
start -deactivate -stop
```

ID	system_settings_remote_management_disable
-----------	---

References	800-53r5	• CM-7, CM-7(1)
	CCE	• CCE-95393-5

9.28. Enforce Session Lock After Screen Saver is Started

A screen saver *MUST* be enabled and the system *MUST* be configured to require a password to unlock once the screensaver has been on for a maximum of 5 seconds.

An unattended system with an excessive grace period is vulnerable to a malicious user.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
  let delay = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.screensaver')\
.objectForKey('askForPasswordDelay'))
  if ( delay <= 5 ) {
    return("true")
  } else {
    return("false")
  }
}
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.screensaver) payload type:

```
<key>askForPasswordDelay</key>
<integer>5</integer>
```

ID	system_settings_screensaver_ask_for_password_delay_enforce	
References	800-53r5	• AC-11
	CCE	• CCE-95395-0

9.29. Enforce Screen Saver Password

Users *MUST* authenticate when unlocking the screen saver.

The screen saver acts as a session lock and prevents unauthorized users from accessing the current user's account.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.screensaver')\
.objectForKey('askForPassword').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.screensaver) payload type:

```
<key>askForPassword</key>
<true/>
```

ID	system_settings_screensaver_password_enforce	
References	800-53r5	• AC-11
	CCE	• CCE-95396-8

9.30. Enforce Screen Saver Timeout

The screen saver timeout *MUST* be set to 1200 seconds or a shorter length of time.

This rule ensures that a full session lock is triggered within no more than 1200 seconds of inactivity.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
function run() {
  let timeout = ObjC.unwrap(
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.screensaver')\
.objectForKey('idleTime'))
  if ( timeout <= 1200 ) {
```

```
    return("true")
  } else {
    return("false")
  }
}
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.screensaver) payload type:

```
<key>idleTime</key>
<integer>1200</integer>
```

ID	system_settings_screensaver_timeout_enforce	
References	800-53r5	• AC-11 • IA-11
	CCE	• CCE-95397-6

9.31. Disable Siri

Support for Siri is non-essential and *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.applicationaccess')\
.objectForKey('allowAssistant').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.applicationaccess) payload type:

```
<key>allowAssistant</key>
<false/>
```

ID	system_settings_siri_disable	
References	800-53r5	• AC-20 • CM-7, CM-7(1) • SC-7(10)
	CCE	• CCE-95398-4

9.32. Ensure Siri Listen For is Disabled

Siri has the ability to listen for "Hey Siri" or "Siri". Listen for *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/sudo /usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.Siri')\
.objectForKey('VoiceTriggerUserEnabled').js
EOS
```

If the result is not **false**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.Siri) payload type:

```
<key>VoiceTriggerUserEnabled</key>
<false/>
```

ID	system_settings_siri_listen_disable	
References	800-53r5	• N/A
	CCE	• CCE-95399-2

9.33. Disable Server Message Block Sharing

Support for Server Message Block (SMB) file sharing is non-essential and *MUST* be disabled.

The information system *MUST* be configured to provide only essential capabilities.

To check the state of the system, run the following command(s):

```
/bin/launchctl print-disabled system | /usr/bin/grep -c '"com.apple.smbd" => disabled'
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/bin/launchctl disable system/com.apple.smbd
```

The system may need to be restarted for the update to take effect.

ID	system_settings_smbd_disable	
References	800-53r5	• AC-17 • AC-3
	CCE	• CCE-95401-6

9.34. Enforce Software Update Downloads Updates Automatically

Software Update *MUST* be configured to enforce automatic downloads of updates is enabled.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.SoftwareUpdate')\
.objectForKey('AutomaticDownload').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.SoftwareUpdate) payload type:

```
<key>AutomaticDownload</key>
<true/>
```

ID	system_settings_software_update_download_enforce	
References	800-53r5	• N/A
	CCE	• CCE-95403-2

9.35. Ensure Software Update is Updated and Current

Make sure Software Update is updated and current.

[Update macOS on Mac](#) or if enrolled in an MDM consult your MDM's documentation for automated methods.

To check the state of the system, run the following command(s):

```
softwareupdate_date_epoch=$(/bin/date -j -f "%Y-%m-%d" "$(/usr/bin/defaults read
/Library/Preferences/com.apple.SoftwareUpdate.plist LastFullSuccessfulDate |
/usr/bin/awk '{print $1}')" "+%s")
thirty_days_epoch=$(/bin/date -v -30d "+%s")
if [[ $softwareupdate_date_epoch -lt $thirty_days_epoch ]]; then
  /bin/echo "0"
else
  /bin/echo "1"
fi
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:



See discussion on how to install software updates.

ID	system_settings_softwareupdate_current	
References	800-53r5	• SI-2
	CCE	• CCE-95405-7

9.36. Disable SSH Server for Remote Access Sessions

SSH service *MUST* be disabled for remote access.

To check the state of the system, run the following command(s):

```
result="FAIL"
enabled=$(/bin/launchctl print-disabled system | /usr/bin/grep '"com.openssh.sshd" =>
enabled')
running=$(/bin/launchctl print system/com.openssh.sshd 2>/dev/null)

if [[ -z "$running" ]] && [[ -z "$enabled" ]]; then
    result="PASS"
elif [[ -n "$running" ]]; then
    result=result+ " RUNNING"
elif [[ -n "$enabled" ]]; then
    result=result+ " ENABLED"
fi
echo $result
```

If the result is not **PASS**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/sbin/systemsetup -f -setremotelogin off >/dev/null
/bin/launchctl disable system/com.openssh.sshd
```



Systemsetup with -setremotelogin flag will fail unless you grant Full Disk Access to systemsetup or its parent process. Requires supervision.

ID	system_settings_ssh_disable	
References	800-53r5	• AC-17 • CM-7, CM-7(1)
	CCE	• CCE-95406-5

9.37. Require Administrator Password to Modify System-Wide Preferences

The system *MUST* be configured to require an administrator password in order to modify the system-wide preferences in System Settings.

Some Preference Panes in System Settings contain settings that affect the entire system. Requiring a password to unlock these system-wide settings reduces the risk of a non-authorized user modifying system configurations.

To check the state of the system, run the following command(s):

```
authDBs=("system.preferences" "system.preferences.energysaver"
"system.preferences.network" "system.preferences.printing"
"system.preferences.sharing" "system.preferences.softwareupdate"
"system.preferences.startupdisk" "system.preferences.timemachine")
result="1"
for section in ${authDBs[@]}; do
    if [[ $(/usr/bin/security -q authorizationdb read "$section" | /usr/bin/xmllint
-xpath 'name(//*[contains(text(), "shared")]/following-sibling::*[1])' -) != "false"
]]; then
        result="0"
    fi
    if [[ $(/usr/bin/security -q authorizationdb read "$section" | /usr/bin/xmllint
-xpath '//*[contains(text(), "group")]/following-sibling::*[1]/text()' -) != "admin"
]]; then
        result="0"
    fi
    if [[ $(/usr/bin/security -q authorizationdb read "$section" | /usr/bin/xmllint
-xpath 'name(//*[contains(text(), "authenticate-user")]/following-sibling::*[1])' -)
!= "true" ]]; then
        result="0"
    fi
    if [[ $(/usr/bin/security -q authorizationdb read "$section" | /usr/bin/xmllint
-xpath 'name(//*[contains(text(), "session-owner")]/following-sibling::*[1])' -) !=
"false" ]]; then
        result="0"
    fi
done
echo $result
```

If the result is not 1, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
authDBs=("system.preferences" "system.preferences.energysaver"
"system.preferences.network" "system.preferences.printing"
"system.preferences.sharing" "system.preferences.softwareupdate"
"system.preferences.startupdisk" "system.preferences.timemachine")

for section in ${authDBs[@]}; do
    /usr/bin/security -q authorizationdb read "$section" > "/tmp/$section.plist"
```

```

class_key_value=$( /usr/libexec/PlistBuddy -c "Print :class" "/tmp/
$section.plist" 2>&1)
if [[ "$class_key_value" == *"Does Not Exist"* ]]; then
    /usr/libexec/PlistBuddy -c "Add :class string user" "/tmp/$section.plist"
else
    /usr/libexec/PlistBuddy -c "Set :class user" "/tmp/$section.plist"
fi

key_value=$( /usr/libexec/PlistBuddy -c "Print :shared" "/tmp/$section.plist"
2>&1)
if [[ "$key_value" == *"Does Not Exist"* ]]; then
    /usr/libexec/PlistBuddy -c "Add :shared bool false" "/tmp/$section.plist"
else
    /usr/libexec/PlistBuddy -c "Set :shared false" "/tmp/$section.plist"
fi

auth_user_key=$( /usr/libexec/PlistBuddy -c "Print :authenticate-user"
"/tmp/$section.plist" 2>&1)
if [[ "$auth_user_key" == *"Does Not Exist"* ]]; then
    /usr/libexec/PlistBuddy -c "Add :authenticate-user bool true" "/tmp/
$section.plist"
else
    /usr/libexec/PlistBuddy -c "Set :authenticate-user true" "/tmp/$section.plist"
fi

session_owner_key=$( /usr/libexec/PlistBuddy -c "Print :session-owner"
"/tmp/$section.plist" 2>&1)
if [[ "$session_owner_key" == *"Does Not Exist"* ]]; then
    /usr/libexec/PlistBuddy -c "Add :session-owner bool false" "/tmp/
$section.plist"
else
    /usr/libexec/PlistBuddy -c "Set :session-owner false" "/tmp/$section.plist"
fi

group_key=$( /usr/libexec/PlistBuddy -c "Print :group" "/tmp/$section.plist"
2>&1)
if [[ "$group_key" == *"Does Not Exist"* ]]; then
    /usr/libexec/PlistBuddy -c "Add :group string admin" "/tmp/$section.plist"
else
    /usr/libexec/PlistBuddy -c "Set :group admin" "/tmp/$section.plist"
fi

/usr/bin/security -q authorizationdb write "$section" < "/tmp/$section.plist"
done

```

ID	system_settings_system_wide_preferences_configure	
References	800-53r5	AC-6, AC-6(1), AC-6(2)
	CCE	CCE-95408-1

9.38. Configure Time Machine for Automatic Backups

Automatic backups *MUST* be enabled when using Time Machine.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.TimeMachine')\
.objectForKey('AutoBackup').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.TimeMachine) payload type:

```
<key>AutoBackup</key>
<true/>
```

ID	system_settings_time_machine_auto_backup_enable	
References	800-53r5	• N/A
	CCE	• CCE-95409-9

9.39. Ensure Time Machine Volumes are Encrypted

Time Machine volumes *MUST* be encrypted.

To check the state of the system, run the following command(s):

```
/usr/bin/sudo /usr/bin/defaults read /Library/Preferences/com.apple.TimeMachine.plist
| grep -c NotEncrypted
```

If the result is not **0**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

1. Go to System Settings → Time Machine

2. Click **Select Disk**
3. Select existing Backup Disk under **Available Disks**
4. Click **Encrypt Backups**
5. Click **Use Disk**

ID	system_settings_time_machine_encrypted_configure	
References	800-53r5	• N/A
	CCE	• CCE-95410-7

9.40. Configure macOS to Use an Authorized Time Server

Approved time server *MUST* be the only server configured for use. As of macOS 10.13 only one time server is supported.

This rule ensures the uniformity of time stamps for information systems with multiple system clocks and systems connected over a network.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.MCX')\
.objectForKey('timeServer').js
EOS
```

If the result is not **pool.ntp.org**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

Create a configuration profile containing the following keys in the (com.apple.MCX) payload type:

```
<key>timeServer</key>
<string>pool.ntp.org</string>
```

ID	system_settings_time_server_configure
-----------	---------------------------------------

References	800-53r5	• AU-12(1) • SC-45(1)
	CCE	• CCE-95411-5

9.41. Enforce macOS Time Synchronization

Time synchronization *MUST* be enforced on all networked systems.

This rule ensures the uniformity of time stamps for information systems with multiple system clocks and systems connected over a network.

To check the state of the system, run the following command(s):

```
/usr/bin/osascript -l JavaScript << EOS
$.NSUserDefaults.alloc.initWithSuiteName('com.apple.timed')\
.objectForKey('TMAutomaticTimeOnlyEnabled').js
EOS
```

If the result is not **true**, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:



The following settings are in the (com.apple.ManagedClient.preferences) payload. This payload requires the additional settings to be sub-payloads within, containing their defined payload types.

Create a configuration profile containing the following keys in the (com.apple.timed) payload type:

```
<key>TMAutomaticTimeOnlyEnabled</key>
<true/>
```

ID	system_settings_time_server_enforce	
References	800-53r5	• AU-12(1) • SC-45(1)
	CCE	• CCE-95412-3

9.42. Ensure Wake for Network Access Is Disabled

Wake for network access *MUST* be disabled.

To check the state of the system, run the following command(s):

```
/usr/bin/pmset -g custom | /usr/bin/awk '/womp/ { sum+=$2 } END {print sum}'
```

If the result is not 0, this is a finding.

Remediation Description

Perform the following to configure the system to meet the requirements:

```
/usr/bin/pmset -a womp 0
```

ID	system_settings_wake_network_access_disable	
References	800-53r5	• N/A
	CCE	• CCE-95417-2

Chapter 10. Inherent

This section reviews the controls that are built-in to macOS, and cannot be configured out of compliance.

10.1. Audit Record Reduction and Report Generation

The system *IS* configured with the ability provide and implement an audit record reduction and report generation capability.

Audit record reduction is a process that manipulates collected audit log information and organizes it into a summary format that is more meaningful to analysts. Audit record reduction and report generation capabilities do not always emanate from the same system or from the same organizational entities that conduct audit logging activities. The audit record reduction capability includes modern data mining techniques with advanced data filters to identify anomalous behavior in audit records. The report generation capability provided by the system can generate customizable reports. Time ordering of audit records can be an issue if the granularity of the timestamp in the record is insufficient.

Audit record reduction and report generation can be done with tools built into macOS such as auditreduce and praudit. These tools are protected by System Integrity Protection (SIP).

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	audit_record_reduction_report_generation	
References	800-53r5	• AU-7

10.2. Allow Information Transfer with Other Operating Systems

The information system *IS* configured to allow the transfer of information to and from other operating systems and users.

The macOS is a UNIX 03-compliant operating system, which allows owners of object to have discretion over who should be authorized to access information.

<https://developer.apple.com/library/archive/documentation/Security/Conceptual/AuthenticationAndAuthorizationGuide/Permissions/Permissions.html>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_allow_info_passed	
References	800-53r5	• AC-3(4)

10.3. Ensure Separate Execution Domain for Processes

The inherent configuration of the macOS *IS* in compliance as Apple has implemented multiple features Mandatory access controls (MAC), System Integrity Protection (SIP), and application sandboxing.

<https://support.apple.com/guide/security/system-integrity-protection-secb7ea06b49/web>

<https://developer.apple.com/library/archive/documentation/Security/Conceptual/AppSandboxDesignGuide/AboutAppSandbox/AboutAppSandbox.html>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_application_sandboxing	
References	800-53r5	• SC-39

10.4. Allow Administrators to Modify Security Settings and System Attributes

The information system *IS* configured to allow administrators to modify security settings and system attributes.

The macOS is a UNIX 03-compliant operating system, which allows administrators of the system to change security settings and system attributes, including those which are kept within preference panes that are locked for standard users. .

<https://support.apple.com/guide/mac-help/change-permissions-for-files-folders-or-disks-mchlp1203/mac>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_change_security_attributes	
References	800-53r5	• AC-3(4)

10.5. Protect Audit Integrity with Cryptographic Mechanisms

The information system *IS* configured to implement cryptographic mechanisms to protect the integrity of audit information and audit tools.

The Apple T2 Security Chip includes a dedicated Advanced Encryption Standard (AES) crypto engine built into the direct memory access (DMA) path between the flash storage and main system memory, which powers line-speed encrypted storage with FileVault and makes internal volume

highly efficient.

https://www.apple.com/euro/mac/shared/docs/Apple_T2_Security_Chip_Overview.pdf



This will only apply to a Mac that includes a T2 security chip.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_crypto_audit	
References	800-53r5	• AU-9(3)

10.6. Enforce Access Restrictions

The information system *IS* configured to enforce access restrictions and support auditing of the enforcement actions.

The inherent configuration of a macOS provides users with the ability to set their own permission settings to control who can view and alter files on the computer.

<https://support.apple.com/guide/mac-help/change-permissions-for-files-folders-or-disks-mchlp1203/mac>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_enforce_access_restrictions	
References	800-53r5	• CM-5(1)

10.7. Generate Error Messages without Exploitable Information

The information system *IS* configured to generate error messages that provide the information necessary for corrective actions without revealing information that could be exploited by adversaries.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_error_message	
References	800-53r5	• N/A

10.8. Configure System to Fail to a Known Safe State if System Initialization, Shutdown, or Abort Fails

The information system *IS* configured to fail to a known safe state in the event of a failed system initialization, shutdown, or abort.

Failure to a known safe state helps prevent systems from failing to a state that may cause loss of data or unauthorized access to system resources.

Apple File System (APFS) is the default file system for Mac computers using macOS 10.13 and all later versions. APFS includes native encryption, safe document saves, stable snapshots, and crash protection; these features ensure that the macOS fails to safe state.

<https://developer.apple.com/videos/play/wwdc2017/715/>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_fail_secure_state	
References	800-53r5	• SC-24

10.9. Allow Administrators to Promote Other Users to Administrator Status

The information system *IS* configured to allow current administrators to promote standard users to administrator user status.

The macOS is a UNIX 03-compliant operating system which allows administrators of the system to grant privileges to other users.

<https://support.apple.com/guide/mac-help/set-up-other-users-on-your-mac-mtusr001/mac>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_grant_privs	
References	800-53r5	• AC-3(4)

10.10. Configure the System to Implement Approved Cryptography to Protect Information

The information system *IS* configured to implement approved cryptography to protect information.

Use of weak or untested encryption algorithms undermines the purposes of utilizing encryption to protect data. The operating system must implement cryptographic modules that adhere to the

higher standards that have been tested, validated, and approved by the federal government.

Apple is committed to the FIPS validation process and historically has always submitted and validated the cryptographic modules in macOS. macOS Tahoe for Apple Silicon will be submitted for FIPS validation. macOS Tahoe for Intel based processors will *NOT* be submitted for FIPS validation.

<https://csrc.nist.gov/Projects/cryptographic-module-validation-program/validated-modules>

<https://support.apple.com/guide/sccc/welcome/web>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement using FIPS Validated Cryptographic Modules.

ID	os_implement_cryptography	
References	800-53r5	• SC-13

10.11. Configure the System to Protect Memory from Unauthorized Code Execution

The information system *IS* configured to implement non-executable data to protect memory from code execution.

Some adversaries launch attacks with the intent of executing code in non-executable regions of memory or in memory locations that are prohibited (e.g., buffer overflow attacks). Security safeguards (e.g., data execution prevention and address space layout randomization) can be employed to protect non-executable regions of memory. Data execution prevention safeguards can either be hardware-enforced or software-enforced; hardware-enforced methods provide the greater strength of mechanism.

macOS supports address space layout randomization (ASLR), position-independent executable (PIE), Stack Canaries, and NX stack and heap protection.

<https://developer.apple.com/library/archive/documentation/Darwin/Conceptual/64bitPorting/transition/transition.html>

https://developer.apple.com/library/archive/qa/qa1788/_index.html

<https://www.apple.com/macOS/security/>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_implement_memory_protection	
References	800-53r5	• SI-16

10.12. Configure the System to Separate User and System Functionality

The information system *IS* configured to isolate security functions from non-security functions.

<https://support.apple.com/guide/security/welcome/web>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_isolate_security_functions	
References	800-53r5	• SC-3

10.13. Only allow authorized users to select auditable events

Without the capability to restrict which roles and individuals can select which events are audited, unauthorized personnel may be able to prevent the auditing of critical events. Misconfigured audits may degrade the system's performance by overwhelming the audit log. Misconfigured audits may also make it more difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_limit_auditable_events	
References	800-53r5	• N/A

10.14. Limit Concurrent GUI Sessions to 10 for all Accounts

The information system *IS* configured to limit the number of concurrent graphical user interface (GUI) sessions to a maximum of ten for all users.

Operating system management includes the ability to control the number of users and user sessions that utilize an operating system. Limiting the number of allowed users and sessions per user helps reduce the risks related to Denial-of-Service (DoS) attacks. This requirement addresses concurrent sessions for information system accounts and does not address concurrent sessions by single users via multiple system accounts. The maximum number of concurrent sessions should be defined based upon mission needs and the operational environment for each system.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_limit_gui_sessions	
References	800-53r5	• AC-10

10.15. Enforce Approved Authorization for Logical Access

The information system *IS* configured to enforce an approved authorization process before granting users logical access.

The inherent configuration of the macOS does not grant users logical access without authorization. Authorization is achieved on the macOS through permissions, which are controlled at many levels, from the Mach and BSD components of the kernel, through higher levels of the operating system and, for networked applications, through the networking protocols. Permissions can be granted at the level of directories, subdirectories, files or applications, or specific data within files or functions within applications.

<https://developer.apple.com/library/archive/documentation/Security/Conceptual/AuthenticationAndAuthorizationGuide/Permissions/Permissions.html>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_logical_access	
References	800-53r5	• AC-3

10.16. Display logoff capability and message to prevent exploitation

Provides a logout capability for user-initiated communications sessions whenever authentication is used to gain access to the system.

Displays an explicit logout message to users indicating the reliable termination of authenticated communications sessions.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_logoff_capability_and_message	
References	800-53r5	• AC-12(1), AC-12(2)

10.17. Ensure the System Implements Malicious Code Protection Mechanisms

The inherent configuration of the macOS *IS* in compliance as Apple has designed the system with three layers of protection against malware. Each layer of protection is comprised of one or more malicious code protection mechanisms, which are automatically implemented and which, collectively, meet the requirements of all applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance for malicious code prevention.

1. This first layer of defense targets the distribution of malware; the aim is to prevent malware from ever launching. The following mechanisms are inherent to the macOS design and constitute the first layer of protection against malicious code:
 - The Apple App Store: the safest way to add new applications to a Mac is by downloading them from the App Store; all apps available for download from the App Store have been reviewed for signs of tampering and signed by Apple to indicate that the app meets security requirements and does not contain malware.
 - XProtect: a built-in, signature-based, anti-virus, anti-malware technology inherent to all Macs. XProtect automatically detects and blocks the execution of known malware.
 - In macOS 10.15 and all subsequent releases, XProtect checks for known malicious content when:
 - an app is first launched,
 - an app has been changed (in the file system), and
 - XProtect signatures are updated.
 - YARA: another built-in tool (inherent to all Macs), which conducts signature-based detection of malware. Apple updates YARA rules regularly.
 - Gatekeeper: a security feature inherent to all Macs; Gatekeeper scans apps to detect malware and/or revocations of a developer's signing certificate and prevents unsafe apps from running.
 - Notarization: Apple performs regular, automated scans to detect signs of malicious content and to verify developer ID-signed software; when no issues are found, Apple notarizes the software and delivers the results of scans to the system owner.
2. The second layer of defense targets malware that manages to appear on a Mac before it runs; the aim is to quickly identify and block any malware present on a Mac in order to prevent the malware from running and further spreading. The following mechanisms are inherent to the macOS design and constitute the second layer of protection against malicious code:
 - XProtect (defined above).
 - Gatekeeper (defined above).
 - Notarization (defined above).
3. The third layer of defense targets infected Mac system(s); the aim is to remediate Macs on which malware has managed to successfully execute. The following mechanism is inherent to the macOS design and constitutes the third layer of protection against malicious code:

- Apple's XProtect: a technology included on all macOS systems. XProtect will remediate infections upon receiving updated information delivered and when infections are detected

<https://support.apple.com/guide/security/protecting-against-malware-sec469d47bd8/1/web/1>

<https://support.apple.com/guide/security/app-security-overview-sec35dd877d0/web>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_malicious_code_prevention	
References	800-53r5	• SI-3

10.18. Map identity for PKI based authentication

Without mapping the certificate used to authenticate to the user account, the ability to determine the identity of the individual user or group will not be available for forensic analysis.

For directory bound systems, the technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_map_pki_identity	
References	800-53r5	• N/A

10.19. Enforce multifactor authentication for network access to privileged accounts

The information system implements multifactor authentication for network access to privileged accounts.

For directory bound systems: The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_mfa_network_access	
References	800-53r5	• N/A

10.20. Enforce multifactor authentication for network access to non-privileged accounts

The information system implements multifactor authentication for network access to non-privileged accounts.

For directory bound systems: The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_mfa_network_non-priv	
References	800-53r5	• N/A

10.21. Obscure Passwords

The information system *IS* configured to obscure feedback of authentication information during the authentication process to protect the information from possible exploitation by unauthorized individuals.

The inherent configuration of a macOS uses NSSecureTextField for any text field that receives a password, which automatically obscures text which is entered.

<https://developer.apple.com/documentation/appkit/nssecuretextfield>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_obscure_password	
References	800-53r5	• IA-5 • IA-6

10.22. The macOS system must uniquely identify peripherals before establishing a connection.

Without identifying devices, unidentified or unknown devices may be introduced, thereby facilitating malicious activity.

Peripherals include, but are not limited to, such devices as flash drives, external storage, and printers.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_peripherals_identify	
References	800-53r5	• N/A

10.23. Must behave in predictable and documented manner

The information system behaves in a predictable and documented manner that reflects organizational and system objectives when invalid inputs are received.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_predictable_behavior	
References	800-53r5	• SI-10(3)

10.24. Prevent Software From Executing at Higher Privilege Levels than Users Executing The Software

In certain situations, software applications/programs need to execute with elevated privileges to perform required functions. However, if the privileges required for execution are at a higher level than the privileges assigned to organizational users invoking such applications/programs, those users are indirectly provided with greater privileges than assigned by the organizations. Some programs and processes are required to operate at a higher privilege level and therefore should be excluded from the organization-defined software list after review.

The inherent configuration of the macOS does not allow for non-privileged users to be able to execute functions requiring privilege.

<https://developer.apple.com/library/archive/documentation/Security/Conceptual/AuthenticationAndAuthorizationGuide/Permissions/Permissions.html>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_prevent_priv_execution	
References	800-53r5	• AC-6(8)

10.25. Configure the System to Block Non-Privileged Users from Executing Privileged Functions

The information system *IS* configured to block standard users from executing privileged functions.

Privileged functions include disabling, circumventing, or altering implemented security safeguards and countermeasures.

The inherent configuration of the macOS does not allow for non-privileged users to be able to execute functions requiring privilege.

<https://developer.apple.com/library/archive/documentation/Security/Conceptual/AuthenticationAndAuthorizationGuide/Introduction/Introduction.html>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_prevent_priv_functions	
References	800-53r5	• AC-6(10)

10.26. Configure the System to Prevent the Unauthorized Disclosure of Data via Shared Resources

The information system *IS* configured to ensure that the unauthorized disclosure of data does not occur when resources are shared.

The inherent configuration of the macOS does not allow for resources to be shared between users without authorization.

<https://developer.apple.com/library/archive/documentation/Security/Conceptual/AuthenticationAndAuthorizationGuide/Permissions/Permissions.html>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_prevent_unauthorized_disclosure	
References	800-53r5	• SC-4

10.27. Prohibit Remote Activation of Collaborative Computing Devices

The inherent configuration of the macOS *IS* in compliance.

Apple has implemented a green light physically next to your camera that will glow when the camera is activated. There is an orange dot indicator by the Control Center pull down menu item to indicate when the system’s microphone is listening or activated.

The macOS has built into the system, the ability to grant or deny access to the camera and microphone which requires the application to have an entitlement to use the device.

<https://support.apple.com/guide/mac-help/use-the-built-in-camera-mchlp2980/mac>

<https://support.apple.com/guide/mac-help/control-access-to-your-camera-mchlf6d108da/mac>

<https://support.apple.com/guide/mac-help/control-access-to-your-microphone-on-mac-mchla1b1e1fe/12.0/mac/12.0>

The technology partially supports this requirement and cannot be configured to be in full compliance.

ID	os_prohibit_remote_activation_collab_devices	
References	800-53r5	• SC-15

10.28. Provide Ability to Disconnect or Disable Remote Access

Without the ability to immediately disconnect or disable remote access, an attack or other compromise taking place would not be immediately stopped. Operating system remote access functionality must have the capability to immediately disconnect current users remotely accessing the information system and/or disable further remote access. The speed of disconnect or disablement varies based on the criticality of missions functions and the need to eliminate immediate or future remote access to organizational information systems. The remote access functionality (e.g., SSH) may implement features such as automatic disconnect (or user-initiated disconnect) in case of adverse information based on an indicator of compromise or attack.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_provide_disconnect_remote_access	
References	800-53r5	• AC-17(9)

10.29. Require users to reauthenticate for privilege escalation

Without reauthentication, users may access resources or perform tasks for which they do not have authorization. When operating systems provide the capability to escalate a functional capability, it is critical the user reauthenticate.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_reauth_privilege	
References	800-53r5	• IA-11

10.30. Require users to reauthenticate when changing authenticators

Without reauthentication, users may access resources or perform tasks for which they do not have authorization. When operating systems provide the capability to change user authenticators, it is critical the user reauthenticate.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_reauth_users_change_authenticators	
References	800-53r5	• IA-11

10.31. Control remote access methods

The information system monitors and controls remote access methods.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_remote_access_methods	
References	800-53r5	• N/A

10.32. Must remove all software components after updated versions installed

Previous versions of software components that are not removed from the information system after updates have been installed may be exploited by adversaries. Some information technology products may remove older versions of software automatically from the information system.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_remove_software_components_after_updates	
References	800-53r5	• SI-2(6)

10.33. Ensure all Federal Laws, Executive Orders, Directives, Policies, Regulations, Standards, and Guidance for Authentication to a Cryptographic Module are Met

The inherent configuration of the macOS *IS* in compliance by implementing mechanisms for authentication to a cryptographic module that meet the requirements of all applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance for such authentication

macOS contains many open source projects that may use their own cryptographic libraries typically for the purposes of maintaining platform independence. These services are not covered by the Apple FIPS Validation of the CoreCrypto and CoreCrypto Kernel modules.

Apple is committed to the FIPS validation process and historically has always submitted and validated the cryptographic modules in macOS. macOS Tahoe for Apple Silicon will be submitted for FIPS validation. macOS Tahoe for Intel based processors will *NOT* be submitted for FIPS validation.

<https://csrc.nist.gov/Projects/cryptographic-module-validation-program/validated-modules>

<https://support.apple.com/guide/sccc/welcome/web>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_required_crypto_module	
References	800-53r5	• IA-7

10.34. Protected Storage for Cryptographic Keys

A system *IS* configured to provide protected storage for cryptographic keys either by hardware protected key store or an organizationally defined safeguard.

Macs with Apple Silicon or T2 processors provide protected storage for cryptographic keys via the secure enclave.

<https://support.apple.com/guide/security/secure-enclave-sec59b0b31ff/1/web/1>



This will only return a proper result on a T2 or Apple Silicon Macs.

```
/usr/sbin/ioreg -w 0 -c AppleSEPManager | /usr/bin/grep -q 'AppleSEPManager'; /bin/echo $?
```

ID	os_secure_enclave	
References	800-53r5	• SC-28(3)

10.35. Configure the System to Separate User and System Functionality

The information system *IS* configured to separate user and system functionality.

Operating system management functionality includes functions necessary for administration and requires privileged user access. Allowing non-privileged users to access operating system management functionality capabilities increases the risk that non-privileged users may obtain elevated privileges. Operating system management functionality includes functions necessary to administer console, network components, workstations, or servers and typically requires privileged user access.

The inherent configuration of the macOS allows only privileged users to access operating system management functionalities.

<https://developer.apple.com/library/archive/documentation/MacOSX/Conceptual/BPSystemStartup/Chapters/DesigningDaemons.html>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_separate_functionality	
-----------	---------------------------	--

References	800-53r5	• MA-4(1) • SC-2
-------------------	-----------------	---

10.36. Encrypt Stored Passwords

The information system *IS* configured to encrypt stored passwords.

Passwords need to be protected at all times, and encryption is the standard method for protecting passwords. If passwords are not encrypted, they can be plainly read (i.e., clear text) and easily compromised.

<https://developer.apple.com/documentation/openssh/openssh-key-authentication-authority>

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_store_encrypted_passwords	
References	800-53r5	• IA-5(1), IA-5(1)(c)

10.37. The macOS Version Must Be Supported by the Vendor

Unsupported software and systems should not be used because fixes to newly identified bugs will not be implemented by the vendor. The lack of support can result in potential vulnerabilities.

Software and systems at unsupported servicing levels or releases will not receive security updates for new vulnerabilities, which leaves them subject to exploitation.

When maintenance updates and patches are no longer available, software is no longer considered supported and should be upgraded or decommissioned.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_supported_operating_system	
References	800-53r5	• N/A

10.38. Terminate all sessions and network connections when maintenance is completed

Terminates session and network connections when non-local maintenance is completed.

The technology supports this requirement and cannot be configured to be out of compliance. The

technology inherently meets this requirement.

ID	os_terminate_session	
References	800-53r5	• N/A

10.39. Uniquely Identify Users and Processes

The macOS is a UNIX 03-compliant operating system. The system uniquely identifies and authenticates organizational users or processes.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_unique_identification	
References	800-53r5	• IA-4

10.40. Verify remote disconnection of sessions

The information system implements remote disconnect verification at the termination of non-local maintenance and diagnostic sessions.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	os_verify_remote_disconnection	
References	800-53r5	• MA-4(7)

10.41. Automatically Remove or Disable Emergency Accounts within 72 Hours

The macOS is able to be configured to automatically remove or disable emergency accounts within 72 hours or less.

Emergency administrator accounts are privileged accounts established in response to crisis situations where the need for rapid account activation is required. Therefore, emergency account activation may bypass normal account authorization processes. If these accounts are disabled, system maintenance during emergencies may not be possible, thus adversely affecting system availability.

Although the ability to create and use emergency administrator accounts is necessary for performing system maintenance during emergencies, these accounts present vulnerabilities to the system if they are not disabled and removed when they are no longer needed. Configuring the macOS to automatically remove or disable emergency accounts within 72 hours of creation mitigates the risks posed if one were to be created and accidentally left active once the crisis is

resolved.

Emergency administrator accounts are different from infrequently used accounts (i.e., local logon accounts used by system administrators when network or normal logon is not available). Infrequently used accounts also remain available and are not subject to automatic termination dates. However, an emergency administrator account is normally a different account created for use by vendors or system maintainers.

To address access requirements, many operating systems can be integrated with enterprise-level authentication/access mechanisms that meet or exceed access control policy requirements.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	pwpolicy_emergency_accounts_disable	
References	800-53r5	• AC-2(2)

10.42. Force Password Change at Next Logon

The macOS is able to be configured to force users to change their password at next logon.

Temporary passwords are often used for new users when accounts are created. However, once logged in to the system, users must be immediately prompted to change to a permanent password of their creation.

For a user to change their password at next logon, run the following command:

```
/usr/bin/pwpolicy -u [USER] -setpolicy "newPasswordRequired=1"
```



Replace [USER] with the username that must change the password at next logon

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	pwpolicy_force_password_change	
References	800-53r5	• IA-5(1)

10.43. Automatically Remove or Disable Temporary User Accounts within 72 Hours

The macOS is able to be configured to set an automated termination for 72 hours or less for all temporary accounts upon account creation.

If temporary user accounts remain active when no longer needed or for an excessive period, these accounts may be targeted by attackers to gain unauthorized access. To mitigate this risk, automated

termination of all temporary accounts *MUST* be set to 72 hours (or less) when the temporary account is created.

If no policy is enforced by a directory service, a password policy can be set with the "pwpolicy" utility. The variable names may vary depending on how the policy was set.

If there are no temporary accounts defined on the system, this is Not Applicable.

The technology supports this requirement and cannot be configured to be out of compliance. The technology inherently meets this requirement.

ID	pwpolicy_temporary_accounts_disable	
References	800-53r5	• AC-2(2)

Chapter 11. Permanent Findings

This section contains the controls that are defined in NIST 800-53 revision 5 but are unable to be configured natively within macOS. It is recommended to implement a third-party solution to meet the controls in this section.

11.1. Prevent the Use of Dictionary Words for Passwords

The macOS should be configured to forbid users to use dictionary words for passwords.

If the operating system allows users to select passwords based on dictionary words, this increases the window of opportunity for a malicious user to guess the password.

To prevent users from using dictionary words for passwords, many operating systems can be integrated with an enterprise-level directory service that meets or exceeds this requirement.



To comply with Executive Order 14028, “Improving the Nation’s Cybersecurity”, OMB M-22-09, “Moving the U.S. Government Toward Zero Trust Cybersecurity Principles”, and NIST SP-800-63b, “Digital Identity Guidelines: Authentication and Lifecycle Management” federal, military, and intelligence communities must adopt the following configuration settings. Password policies must not require the use of complexity policies such as upper characters, lower characters, or special characters. Password policies must also not require the use of regular rotation. Password policies should define a minimum length. Multifactor authentication should be used where ever possible.

For systems not requiring mandatory smart card authentication or those that are not bound to a directory, the technology does not support this requirement. This is an applicable-does not meet finding.

ID	pwpolicy_prevent_dictionary_words	
References	800-53r5	• N/A

Chapter 12. Supplemental

This section provides additional information to support the guidance provided by the baselines.

12.1. CIS Manual Recommendations

List of CIS recommendations that are manual check in the CIS macOS Benchmark.

Section	System Settings
Recommendations	1.7 Ensure the System is Managed by a Mobile Device Management (MDM) Software

Section	System Settings
Recommendations	2.1.1.1 Audit iCloud Keychain 2.1.1.2 Audit iCloud Drive 2.1.1.4 Audit Security Keys Used With Apple Accounts 2.1.1.5 Audit Freeform Sync to iCloud 2.1.1.6 Audit Find My Mac 2.1.2 Audit App Store Password Settings 2.3.3.11 Ensure Computer Name Does Not Contain PII or Protected Organizational Information 2.4.1 Audit Menu Bar and Control Center Icons 2.5.2.2 Ensure Listen for Siri is Disabled 2.6.1.3 Audit Location Services Access 2.6.2.1 Audit Full Disk Access for Applications 2.6.3.5 Ensure Share iCloud Analytics Is Disabled 2.6.7 Audit Lockdown Mode 2.7.2 Audit iPhone Mirroring 2.8.1 Audit Universal Control Settings 2.10.1.1 Ensure the OS Is Not Active When Resuming from Standby (Intel) 2.12.2 Audit Touch ID 2.14.1 Audit Game Center Settings 2.15.1 Audit Notification & Focus Settings 2.16.1 Audit Wallet & Apple Pay Settings 2.17.1 Audit Internet Accounts for Authorized Use

Section	Logging and Auditing
Recommendations	3.6 Audit Software Inventory

Section	System Access, Authentication and Authorization
----------------	---

Recommendations	5.2.3 Ensure Complex Password Must Contain Alphabetic Characters Is Configured 5.2.4 Ensure Complex Password Must Contain Numeric Character Is Configured 5.2.5 Ensure Complex Password Must Contain Special Character Is Configured 5.2.6 Ensure Complex Password Must Contain Uppercase and Lowercase Characters Is Configured 5.3.1 Ensure All User Storage APFS Volumes are Encrypted 5.3.2 Ensure All User Storage CoreStorage Volumes are Encrypted
------------------------	--

Section	Applications
Recommendations	6.1.1 Ensure Show All Filename Extensions Setting is Enabled 6.2.1 Ensure Protect Mail Activity in Mail Is Enabled 6.3.2 Audit History and Remove History Items 6.3.5 Audit Hide IP Address in Safari Setting 6.3.8 Audit Autofill 6.3.9 Audit Pop-up Windows 6.5.1 Audit Passwords